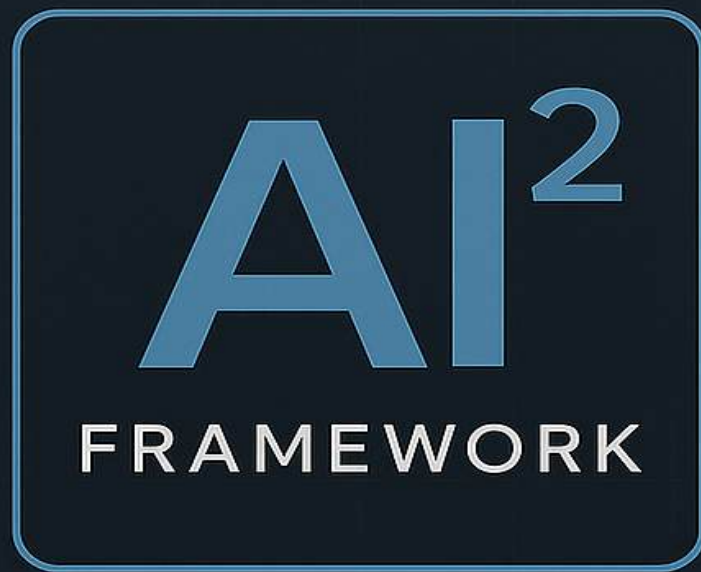




Artificial Intelligence Adversary Imitation Framework

BRANDON LEE, CISSP



Version 1.2

2025

Abstract

The AI² Framework introduces a structured, technically rigorous methodology for assessing the security and risk posture of high-risk AI systems through adversarial imitation. Designed to integrate with offensive security programs, this framework uniquely maps AI-specific risks to adversarial testing techniques, leveraging the NIST AI Risk Management Framework, MITRE ATLAS, and leading practices from Microsoft, IBM, and others. It provides actionable guidance for red teams to evaluate generative and agentic AI systems, offering pre-assessment checklists, risk-to-tactic mappings, and threat modeling tailored to both model and application layers. The AI² Framework serves as both a practical implementation guide and a comprehensive risk reference, enabling organizations to adopt AI technologies responsibly while addressing emerging threats, complex attack surfaces, and evolving regulatory expectations. This version delivers a full workflow to support continuous risk identification, targeted adversarial assessment, and informed control implementation.



AI² FRAMEWORK

ARTIFICIAL
INTELLIGENCE
ADVERSARY
IMITATION

This is a living publication.
As AI continues to evolve and feedback comes in, updates will continue to be published as minor version changes.

Contents

4	Executive Summary
6	AI ² Framework Flowchart
7	AI Solutions
8	AI Solution Layers
9	Single vs. Multimodal
12	Attack Surface Impact
13	Agentic AI Solution Layers Considerations
14	Identify High-Risk AI
15	AI Risk Profile
15	New ($\Delta\text{Risks}_{\text{AI}}$)
16	Responsible AI (Harms)
18	Documented Risks
25	Risk Impact Areas
29	Risk Management Framework (RMF)
33	Tailoring AI Risk Profile
35	Adversary Imitation Assessment Methodology
35	Pre-Assessment Actions
36	Pre-Assessment Checklist for Adversarial Testing of AI Systems
37	Mapping Risks to Tactics, Tactics to Techniques (RTTs)
40	Adversary Imitation Assessment Target
41	Align RTTs to Assessment Target
46	Threat Modeling Approach
49	Agentic AI Nuances
51	Tooling
57	TL;DR: Bring It All Together
58	Emerging Risks Feedback (Maintenance Loop)
60	Appendix I: Raw Risk List
75	Appendix II: Out of Scope Risks: Possible Alignments
77	About the Author
78	Version Control

Executive Summary

The AI² Framework provides a structured, risk-informed approach to managing the unique risks introduced by Artificial Intelligence.

Artificial Intelligence (AI) refers to systems or programs that perform tasks typically requiring human intelligence, i.e., reasoning, learning, perceiving, or making decisions, by processing inputs and producing contextually appropriate outputs. While often conflated with the models that power them, AI solutions are considered “intelligent” based on the quality and relevance of the outputs their models generate.

Developed to support both strategic and technical stakeholders, the framework fulfills three core objectives:

Enable AI Adoption Through Risk Mitigation

The AI² Framework helps organizations establish compliant, research-driven AI risk strategies to safely adopt and benefit from AI. Built on insights from nearly thirty publications, it bridges broad industry guidance with targeted implementation steps.

Establish the Adversary Imitation Assessment Function

AI² introduces a novel adversarial testing methodology - adversary imitation - as an extension of the organization’s offensive security function. This pivot occurs after the Risk Management Framework (RMF) step and is key to aligning controls with AI-specific threats.

Adversary Imitation is a risk-centric evolution of red teaming, defined by the Artificial Intelligence Adversary Imitation Framework to address specific AI-introduced risks. Adversary imitation combines adversarial testing, a form of model-specific evaluation, with threat actor emulation from traditional offensive security. The goal is to assess AI systems using a defined testing baseline while adopting an attacker’s mindset to uncover exploitable behaviors or vulnerabilities unique to AI.

Deliver a Simple and Comprehensive Framework

Designed to be both easy to follow and technically rigorous, the AI² Framework simplifies complex AI risk topics and supports awareness, control design, and readiness assessments. The process is simple to follow for reproduction in different contexts, and the end result is comprehensive and compliant with both domestic and international regulations, legislation, and frameworks. Of note, the AI² Framework workflow incorporates a feedback loop for emerging risks to ensure each version is current with risks discovered after this framework is released.

The AI² Framework begins with foundational steps applicable to any organization, producing detailed artifacts that support multiple control implementations. The framework narrows focus at the RMF commit point, leveraging the NIST AI RMF (100-1) and GenAI Profile (600-1) to define action steps for adversarial testing. From there, the adversary imitation methodology becomes the central product of this release. Nonetheless, the deconstruction of AI Solutions into AI Solution Layers; the risk enumeration, categorization, and mitigation strategies; the mapping of workflow steps to applicable RMF framework action steps; the mapping of risks to adversarial tactics and tools; and the in-depth approach to engineering compliant, risk mitigating controls demonstrated in this framework are applicable to all organizations and controls.

While uniquely structured, the AI² Framework aligns closely with various aspects of several industry-recognized frameworks (NIST AI RMF 100-1 and 600-1) and leaders in the AI space (IBM risk atlas, Google SAIF, and Microsoft's AI Red-Teaming Methodology, particularly in it's approach to risk categorization and adversarial control design).

In summary, the AI² Framework:

- Establishes adversarial imitation assessments tailored to AI-specific risks.
- Informs enterprise AI policy and standards through in-depth risk profiling artifacts.
- Deepens technical and strategic understanding of AI threats, attacks, mitigations, and applicable controls.
- Provides a risk-informed approach to AI governance.

AI² Framework Flowchart

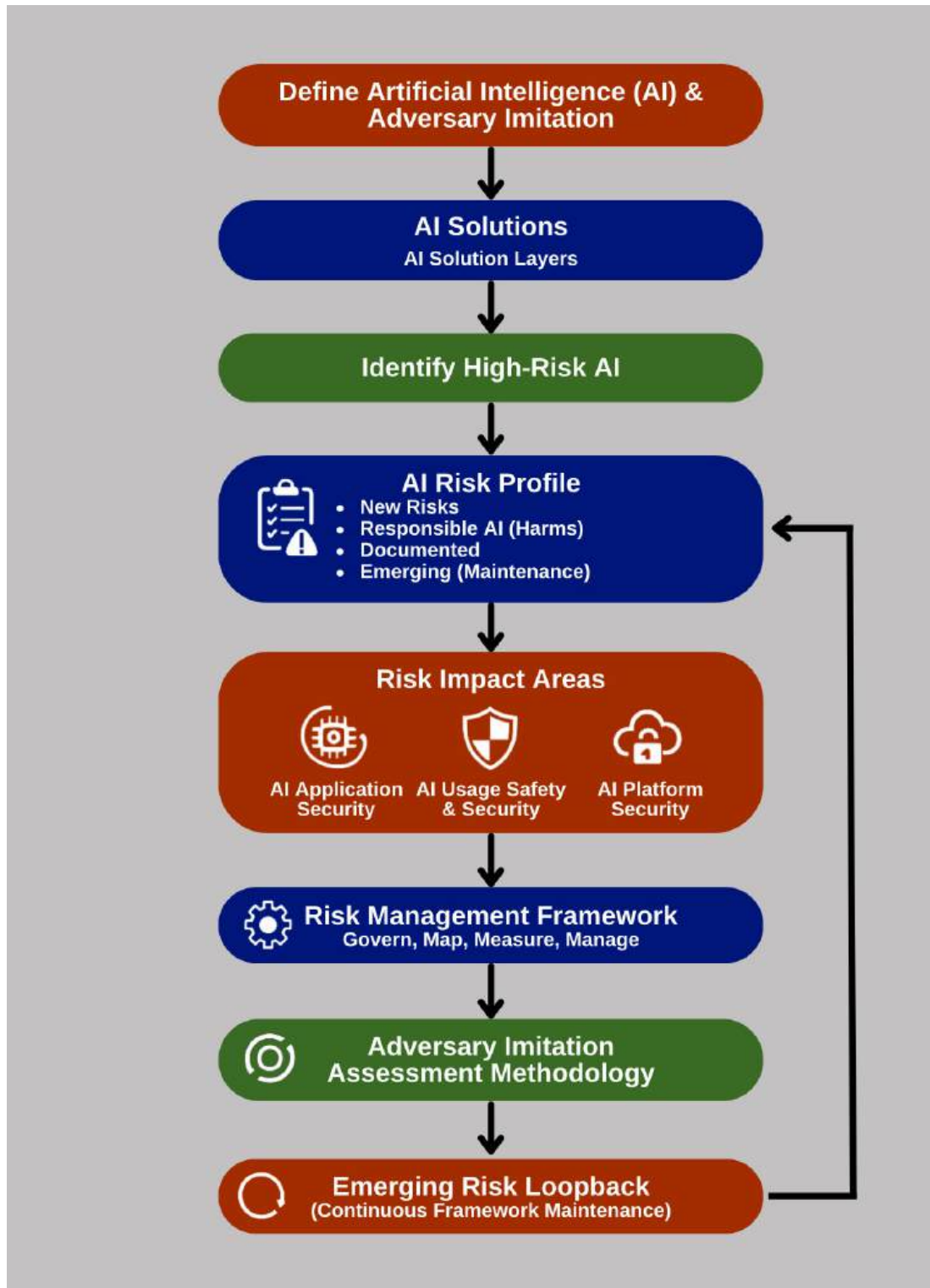


Figure 1: Flow of the AI² Framework.

AI Solutions

The AI² Framework broadly defines **AI Solutions** as applications utilizing AI functionality. Not all AI-specific risks will apply to all AI Solutions, but all AI Solutions introduce certain AI-specific risks. Knowing the AI Solutions utilized is the first step towards specifying AI risks that must be managed as it allows for the list of risks compiled in the *AI Risk Profile* step to be tailored to a given AI Solution based on risks pertinent to that AI Solution.

To understand the risks introduced by an AI solution, it is insufficient to only consider the AI Solution at the application or use-case level ¹. Instead, each **layer** of an AI solution must be considered. The *AI Solutions* step of the AI² Framework introduces the **AI Solution Layers** sub-framework to deconstruct, analyze, and adequately document the risks of an AI Solution.

In the view of the author, Versions 1.0 & 1.1 over-simplified the "AI Type" step by generalizing AI fields/techniques and capabilities as broad, generic groups, failing to properly categorize and distinguish the different components of an AI solution and therefore failing to consider the various distinct components, or **layers**, of that solution. Each layer potentially introduces a new or expanded attack surface and identifies the component most likely to introduce AI risks, all of which must be considered when attempting to document a thorough representation of an AI solution's attack surface.

For example, Versions 1.0 & 1.1 listed "Natural Language Processing (NLP)" as an "AI Type"; however, this technically neither correctly classifies NLP in its appropriate AI context nor adequately analyzes an AI solution built on NLP. Version 1.2 appropriately classifies NLP as a *field/technique* of AI and deconstructs AI solutions utilizing NLP to an appropriate depth via the introduction and implementation of the five-tiered **AI Solution Layers** sub-framework, enabling a risk-analysis at each layer of the AI solution and isolating the primary driver of AI risks. This provides a more efficient, holistic, and accurate AI risk identification methodology.

¹ Examples of "application or use-case level" include "chatbot", "agentic AI", or "computer vision". While each of these examples are useful categorizing terms in a risk alignment effort, alone they are insufficient to articulate an appropriately inclusive risk profile as the same application or use-case will often have varying sub-components that introduce different AI risks.

AI Solution Layers

The AI Solution Layers sub-framework¹ deconstructs a given AI Solution into distinct layers to achieve the following:

- Assist in the identification of applicable AI risks introduced by an AI Solution to the most comprehensive degree possible
- Assist in the alignment of pertinent AI risks to a given AI Solution to improve efficiency in AI risk management control selections and processes
- Identify the layer(s) of the AI solution responsible for the introduction of the greatest number or high severity AI risks

The AI² Framework considers five distinct **AI Solution Layers**:

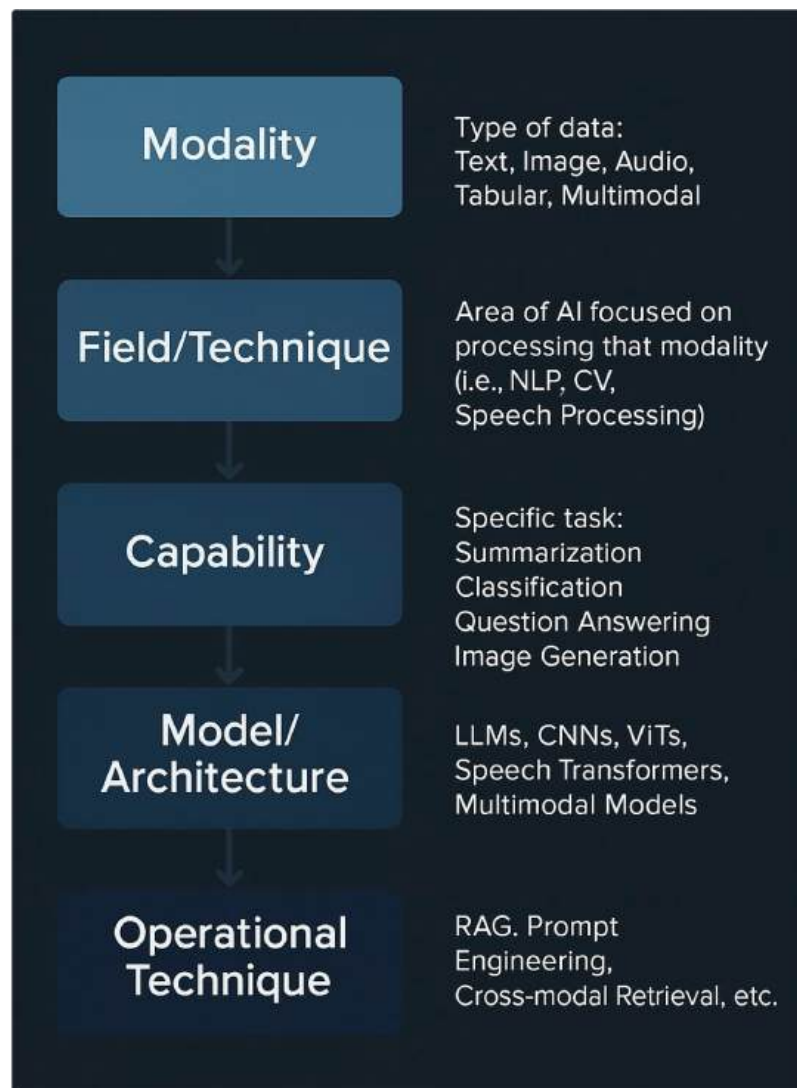


Figure 2: AI Solution Layers

Table 1a provides a brief description of each layer:

Table 1a: AI Solution Layers

Layer	Description
Modality	Type of data: Text, Image, Audio, Tabular, Multimodal
Field/Technique	Area of AI focused on processing that modality (i.e., NLP, CV, Speech Processing)
Capability	Specific task: Summarization, Classification, Question Answering, Image Generation
Model/Architecture	LLMs, CNNs, ViTs, Speech Transformers, Multimodal Models
Operational Technique	RAG, Prompt Engineering, Cross-modal Retrieval, etc.

Single vs. Multimodal

Single-modal AI Solutions involve the ingestion of a single data source, i.e., a question-answering chatbot that only accepts user text as input. With the exception of AI Agents (discussed below), single modal AI Solutions will often align neatly with the AI Solution Layers sub-framework.

The table below lists generic AI Solutions 1-4 with common modalities and corresponding field/techniques, capabilities, model/architecture, and operational techniques:

Table 1b.1: AI Solution Layering (Single-Modal)

Layer	AI Solution 1	AI Solution 2	AI Solution 3	AI Solution 4
Modality	Text (natural language)	Images, Videos	• Speech • Sounds	Structured data (tables)
Field/Technique	Natural Language Processing (NLP)	Computer Vision	Speech Processing	ML for Structured Data
Capability	Text Classification, Summarization, QA, Generation	Image Classification, Object Detection, Image Generation, Segmentation	Speech Recognition (ASR), Speech Synthesis (TTS), Speaker Identification	Fraud Detection, Predictive Modeling, Recommendation

Model/Architecture	LLM (i.e., GPT-4, BERT)	CNNs (ResNet, EfficientNet), Vision Transformers (ViT)	Wav2Vec2.0, Whisper, DeepSpeech	XGBoost, LightGBM, TabNet, Neural Networks
Operational Technique	RAG, Prompt Engineering	Zero-shot Learning, Self-Supervised Pretraining	CTC, Self-Supervised Pretraining	Feature Engineering, AutoML

Multimodal AI solutions process and integrate multiple types of input data, i.e., text, images, and audio. For example, ChatGPT may be asked to read the text embedded in an image and provide a textual summary, combining vision and language capabilities.

To effectively assess the risks associated with a multimodal AI solution, it is important to evaluate:

- **Modality-specific risks**, by analyzing each input type (i.e., image, text, audio) independently using the AI Solution Layers model, and
- **Cross-modal risks**, by examining how modalities interact, as new or emergent risks may arise from the integration and orchestration of multiple modalities.

Table 1b.2 below demonstrates this approach. It presents a generic multimodal AI solution that is assessed both **holistically**, i.e., at the **integration layer**, and **individually** by applying the AI Solution Layers model to each modality.

Before reviewing the table, it is important to understand the **integration layer** as that is what the “holistic” column is referencing. When enumerating risks applicable to multimodal models, the integration layer is an essential consideration. This is not a physical layer but the logical point at which multiple modalities interact. While abstract, the risks applicable to the integration layer tend to follow logically.

Examples of multimodal-specific risks occurring at the integration layer:

- **Emergent behaviors**: arise when modalities interact, i.e., adversarial prompts embedded in images that trigger unexpected LLM responses
- **Cross-modal leakage**: occurs when one data type interferes with the processing of another, i.e., image data influences a text response in unsafe or unexpected ways
- **Misalignment or bias**: neither might be present in single-modality inputs but could appear when combined

TL;DR: When considering multimodal AI, understand which modalities interact and how this interaction could introduce unique risks via unforeseen attack vectors.

Table 1b.2: AI Solution Layering (Multimodal)

Layer	Text	Vision	Holistic
Modality	Text (natural language)	Images, Videos	Mixed inputs (text + images)
Field/Technique	NLP (Natural Language Processing)	CV (Computer Vision)	Multimodal ML / Cross-modal Alignment
Capability	Text Classification, Summarization, Question Answering, Generation	Image Classification, Object Detection, Image Generation, Segmentation	Visual Question Answering (VQA), Image Captioning, Multimodal Retrieval
Model/Architecture	LLM (i.e., GPT-4, BERT), fine-tuned models	CNNs (ResNet, EfficientNet), Vision Transformers (ViT)	Flamingo (DeepMind), GPT-4V, CLIP (OpenAI), BLIP
Operational Technique (optional, advanced)	RAG (Retrieval-Augmented Generation), Prompt Engineering	Zero-shot Learning, Self-Supervised Pretraining	Cross-modal retrieval techniques, Latent Space Alignment

Attack Surface Impact

Each layer of the AI Solution Layers sub-framework presents risks and potentially unique attack surfaces. One consideration to assist in the prioritization of risk mitigation efforts is to determine which layer(s) are responsible for introducing the greatest number or highest severity AI risks.

Note the highlighted portions under the *Attack Surface Impact* column. These layers often introduce significant AI risks and are therefore a common starting point when performing this exercise. Keep in mind each *Attach Surface Impact* could vary depending on the specific AI Solution.

Table 1c: Layer Attack Surface Impact

Layer	Attack Surface Impact	Examples
Modality	Baseline surface (input trust assumptions)	Is the text safe? Is it adversarial?
Field/Technique	Exposes technical vulnerabilities specific to the domain	NLP: prompt injection, data leakage, ambiguous language understanding
Capability	Attack surface depends on task type, i.e., Generative AI solutions greatly expand an attack surface.	QA: hallucination, misclassification, info disclosure, harms
Model/Architecture	Vulnerabilities in model internals	LLM: prompt injection, jailbreaks, data extraction
Operational Technique	Potentially major attack surface expansion based on technique chosen	RAG: retrieval poisoning, injection into retrieved data; Prompt engineering: prompt injections, confusion attacks

As shown above, the attack surface of an AI Solution is primarily a function of its model/architecture and the operational techniques leveraged by the AI Solution

With this said, be mindful of how each layer introduces risks that should be considered.

Agentic AI Solution Layers Considerations

The peculiarities of Agentic AI are covered in depth in a later section (see *Agentic AI Nuances*), but a brief introduction is necessary here due to their relevance to the previous analysis. Wherever possible, Agentic AI solutions should be broken down using the same AI Solution Layering approach applied to traditional systems.

However, Agentic AI does not fit neatly within this model. While it may use familiar capabilities (i.e., LLMs, retrieval techniques (RAG), or generative outputs), Agentic AI introduces a distinct operational paradigm - one based on **autonomous action**, **goal pursuit**, and **decision-making**. These systems often orchestrate multiple layers simultaneously, integrating modalities and techniques in ways that blur traditional layer boundaries.

As a result, Agentic AI must be assessed across the full span of AI Solution Layers. Each layer should still be classified and tested individually, but to achieve sufficient assurance, Agentic AI must also be tested holistically, with all applicable risks considered—especially those tied to autonomy, orchestration, and emergent behaviors.

Remember, Agentic AI introduces a new class of cybersecurity risk - not only does it carry the same risks as traditional AI Solutions, its autonomous nature means it must be considered an independent **threat actor**.

Identify High-Risk AI

High-risk AI solutions carry the greatest potential for harmful impact and regulatory non-compliance, particularly due to legislative mandates that require continuous assurance and robust risk mitigation controls. Consequently, these systems demand the broadest scope of safeguards, thereby serving as a benchmark that can be tailored to lower-risk AI use cases. The AI² Framework utilizes two examples of high-risk AI as described below.

Referencing **Table 1c: Layer Attack Surface Impact**, the capability and operational technique layers present the most significant or numerous AI risks. A common AI capability in high demand today is **generative AI**, and given the unique and distinct risks of agentic AI, its frequent alignment with both the capability and operational technique layers, and its growing popularity, **agentic AI** are both considered **high-risk AI**.

High-Risk AI includes:

- **Generative AI**
- **Agentic AI**
- AI solutions meeting the criteria established by the *EU AI Act*, including Safety-Critical AI (autonomous vehicles), Healthcare AI (diagnostic imaging), Financial AI (algorithmic trading), and Cyber Security AI (automated incident response playbooks)

Exploring a practical basis for establishing generative and agentic AI as high-risk:

- Generative AI (GenAI or GAI):
Creates new content based on learned patterns → **unpredictable**
Key risks:
 - Harmful Content Generation
 - Hallucinations & Fabrications
- Agentic AI (AI agents or agents)
Autonomously execute actions toward goals → **unpredictable**
Key risks:
 - Emergent Goals & Autonomy (Goal Drift)
 - Deceptive Behaviors

Harmful content is a serious risk, and emergent goals are almost eerie to learn about; however, it is the **unpredictable** nature of generative and agentic AI that drives their high-risk designation, where the consequence of this is both generative and agentic AI require layered protection, continuous monitoring, and routine adversarial testing.

AI Risk Profile

$$\sum \Delta Risks_{AI} + Risks_{Responsible\ AI} + Risks_{Documented} = Risk_{AI\ Profile}$$

Table 2: AI Risk Types

AI Risk Type	Description
New	Risks introduced by the AI solution.
Responsible AI	Generation of or failure to prevent harms.
Documented	Risks documented in internal policies and standards and public frameworks and regulations.
Emerging Risks	Emerging AI risks fed into the workflow as part of maintenance.

New ($\Delta Risks_{AI}$)

New risks capture the novel threat vectors created by the rapidly evolving and complex nature of AI technology—from unexpected emergent behaviors to novel adversarial tactics. These risks can be articulated in the sense they have been here, i.e., emergent behavior, however it is difficult to plan a mitigation strategy for a risk that has not been discovered yet.

This speaks to 1) the criticality of a layered defense but 2) an OECD reference to the importance of a red team function for identifying unknown risks:

“Both known and unknown AI risks should be anticipated to prevent harm. Unknown risks might include risks to robustness (i.e. breakdown); security (i.e. hacks); secondary uses or misuses of a system, including use of pre-packaged coding for malicious purposes; psychological and social impact; and reputational risks. Risk and impact assessments can be conducted to identify risks and design mitigation strategies before, during, and after deployment. One approach to identifying unknown risks is known as “red teaming”, which refers to systematic and controlled attempts to probe and expose flaws and weaknesses in a system, process, or organisation to identify and mitigate unknown risks.”

-from OECD: Advancing Accountability in AI

Considering this, the current AI Risk Profile is:

Table 3: New Risks

Reference	Risk
Center for AI Safety (CAIS)	Emergent Goals/Behavior
OECD: Advancing Accountability in AI	Unknown AI Risks

Responsible AI (Harms)

“Responsible AI aims to prioritize people in our design process, considering both the benefits and potential harms that AI systems may have on society.” This is a quote from Microsoft, a company who has built a comprehensive approach to managing the risks of harm in their AI solutions. In this regard, harm reflects concerns over whether an AI solution is used in ways that uphold fairness, protect privacy, and maintain transparency and accountability.

Defined by the Center for Security and Emerging Technology (CSET) as “when an entity experiences harm (or potential for harm) that is directly linked to the behavior of an AI system,” harm focuses on the potential ethical, societal, and safety-related impacts from deploying AI systems. Harm can be tangible and intangible, examples of both follow below:

Tangible Harm:

- Autonomous vehicle crashes into another vehicle
- AI trading algorithm executes unauthorized trades resulting in grave financial loss
- An LLM outputs medical data, resulting in a HIPAA violation

Intangible Harm:

- AI-generated toxic or biased outputs lead to emotional trauma
- AI system is publicly criticized for reinforcing gender bias
- Facial recognition AI disproportionately misidentifies people of color

Mitigations should be in place to prevent the materialization of harms from any AI system, especially generative AI systems with new content that could bypass a filtering system. Red teams can simulate or reveal vulnerabilities that *lead to* physical, financial, or data harms, but other controls should be in place to further reduce the risk of harm.

The AI² Framework lists the categories of harm with relevant examples in *Table 4: Harm Categories*. Some prominent organizations rank the severity level of a harmful output, mostly to determine the applicable follow up actions and consequences. If this is of interest, the Microsoft harm rating system is a good place to start.

Table 4: Harm Categories

Harm Category	Example
Physical Harm	Injury from autonomous system
Psychological Harm	Toxic chatbot causing trauma
Financial/Economic Harm	Biased loan denial, unauthorized trading
Informational Harm	Privacy breach, IP leakage, prompt inversion
Reputational Harm	False claims generated by AI
Discrimination & Inequity	Biased hiring algorithm
Autonomy and Agency Harm	Covert manipulation or deceptive agents
Social & Democratic Harm	AI-generated propaganda, loss of civic trust
Environmental Harm	High carbon footprint of AI models
Legal/Regulatory Harm	GDPR noncompliance, unauthorized surveillance
Operational Harm	Service outage due to adversarial inputs
Ethical/Value-Based Harm	Violating ethical norms

Consolidating the two tables produced so far, the AI Risk Profile is:

Table 5: AI Risk Profile Considering Responsible AI (Harms)

Risk	Description
Emergent Goals/Behavior	Unintended objectives or behaviors that arise from the AI's training data or optimization functions.
Unknown AI Risks	Unanticipated vulnerabilities or consequences not yet identified due to the novelty or complexity of the AI.
Physical Harm	AI-driven actions that could cause bodily injury or damage (i.e., in robotics, autonomous vehicles).
Psychological Harm	Negative mental or emotional effects caused by interactions

	with AI (i.e., manipulative or toxic content).
Financial/Economic Harm	Monetary losses from incorrect predictions, fraud enablement, or disruption of markets or business models.
Informational Harm	Misinformation, disinformation, or degradation of information quality caused or amplified by AI systems.
Reputational Harm	Damage to an individual's or organization's public image due to AI errors, misuse, or controversial outputs.
Discrimination & Inequity	Biased outcomes from AI that disproportionately harm protected or vulnerable groups.
Autonomy and Agency Harm	Erosion of human control or decision-making ability due to overreliance or deceptive AI behavior.
Social & Democratic Harm	Undermining trust in institutions, election integrity, or public discourse through AI-enabled manipulation.
Environmental Harm	Resource-intensive AI processes (i.e., training large models) that contribute to environmental degradation.
Legal/Regulatory Harm	Violations of laws, data regulations (i.e., GDPR), or resulting fines and litigation stemming from AI use.
Operational Harm	Business disruption or process failure caused by AI errors, outages, or integration issues.
Ethical/Value-Based Harm	Breaches of societal or organizational values, even if legally permissible, due to AI decisions or outputs.

Documented Risks

Documented risks are known AI risks accounted for in enterprise policies and standards as well as public frameworks, legislation, regulations, and publications. Having compiled AI-specific risks from over two dozen sources, the number of documented AI risks is extensive, as shown below in the most current AI Risk Profile:

Table 6: AI Risk Profile After Considering Documented Risks

AI Risk Profile	
New Risks	Description
Emergent Goals/Behavior	AI systems developing unintended objectives or behaviors that diverge from their original design.
Unknown AI Risks	Hazards not yet identified due to the evolving and opaque nature of AI technologies.

Responsible AI (Harm)	Description
Physical Harm	Bodily injury or death caused by AI-controlled machinery or systems.
Psychological Harm	Emotional distress or mental health impacts from AI interactions or outputs.
Financial Harm	Monetary losses resulting from AI errors or fraudulent AI-driven schemes.
Economic Harm	Broad market disruptions or job displacement driven by AI adoption.
Informational Harm	Damage from misinformation, data breaches, or compromised data integrity.
Reputational Harm	Loss of trust or credibility for individuals or organizations due to AI actions.
Discrimination & Inequity	Unfair treatment of people or groups because of biased AI decisions.
Autonomy and Agency Harm	Erosion of individuals' ability to make free, informed choices under AI influence.
Social & Democratic Harm	Undermining of social cohesion or democratic processes via AI-driven manipulation.
Environmental Harm	Ecological damage from AI's energy use or environmentally harmful automated actions.
Legal Harm	Regulatory penalties or lawsuits triggered by AI non-compliance or harmful outcomes.
Operational Harm	Disruption to critical business or infrastructure operations due to AI failures.
Ethical/Value-Based Harm	Violations of moral or societal norms by AI, such as privacy intrusions.
Regulatory Harm	Sanctions or restrictions imposed when AI systems breach legal requirements.
Documented Risks	Description
Social Engineering	AI-generated phishing or deceptive content that tricks users into revealing secrets.
Malicious Code Generation	AI producing harmful scripts or malware code.
Vulnerability Discovery	AI tools automating the finding of security flaws.
Identity Impersonation and Synthetic Identity	Creation or misuse of fake identities via AI.

Biased Data	Training datasets reflecting prejudices, leading to unfair model outputs.
Statistical uncertainty in pre-trained models	Inherent unpredictability in model predictions from limited data.
Privacy risk due to enhanced data-aggregation capability for AI systems	Combining datasets to reveal sensitive information.
Side-effects not visible in statistical measures	Unintended behaviors that standard metrics miss.
Increased Attack Surface	New vulnerabilities introduced by adding AI components.
Complex Attack Surface	Interconnected AI pipelines creating intricate security gaps.
Complex Systems	High system complexity leading to unexpected failure modes.
CBRN content generation	AI generating chemical, biological, radiological, or nuclear threat content.
Human-AI Interaction Risks	Miscommunications or errors at the human–AI interface.
Information Integrity	Ensuring AI outputs remain accurate and untampered.
Lower Offensive Cyber Barriers	AI reducing skill requirements for sophisticated attacks.
Third-party data or component trustworthiness	Risks from unvetted external AI services or datasets.
Vector and Embedding Weaknesses	Exploitable flaws in model feature representations.
Unbounded Consumption (Sponge Examples)	AI consuming excessive resources or data beyond intended limits.
Excessive Data Handling	Overcollection or misuse of data raising privacy and compliance concerns.
Insecure Integrated Component	Vulnerabilities from poorly secured AI modules within larger systems.
Rogue Actions	AI taking unauthorized or harmful actions outside its intended scope.
Output Integrity Attack	Tampering with AI responses to mislead downstream systems.
Controllability and Autonomy Risks	Difficulty maintaining human oversight over autonomous AI.
Reliability and Robustness Risks	AI failures under adversarial or unexpected inputs.
Bias and Fairness Risks	Unfair treatment resulting from skewed model behavior.
Safety and Resilience Risks	Weaknesses affecting AI's safe operation and recovery.
Data Quality and Integrity Risks	Poor or corrupted data undermining AI performance.

Automated Decision-Making without Safeguards	AI making unchecked decisions without human review.
Inadequate Data Subject Rights Implementation	Failure to honor user rights like deletion or portability.
Insecure AI Data or Models	Insufficient protection of training data or model artifacts.
Insecure Model Output	Lack of validation and protection for AI-generated outputs.
Insider Threat/Internal Misuse of AI	Authorized users abusing AI capabilities maliciously.
Lack of Incident Reporting Mechanisms	No processes to detect or report AI-related incidents.
Lack of Risk Management System	Absence of a formal framework for AI risk identification and mitigation.
Use of Prohibited AI Applications	Deploying AI in contexts banned by policy or regulation.
Data usage restrictions	Policies limiting permissible uses of data in AI workflows.
Data acquisition restrictions	Controls on sourcing data to ensure legality and ethics.
Data transfer restrictions	Limits on moving data across jurisdictions or networks.
Confidential information in data	Sensitive details embedded in datasets requiring protection.
Personal information in data	Inclusion of PII that mandates privacy safeguards.
IP information in prompt	Proprietary content embedded in AI inputs risking leakage.
Attribute inference attack	Deriving private attributes from model outputs.
Misclassification of AI risk tier	Incorrectly prioritizing AI risks, leading to misallocation of resources.
Data poisoning	Inserting malicious samples into training data to corrupt models.
Model poisoning	Direct tampering with model parameters or weights.
Prompt Injection	Crafting inputs that hijack AI behavior.
Prompt Leaking	Exposing sensitive system prompts through user interactions.
Prompt Priming	Biasing AI outputs by preloading specific context.
Jailbreak Attacks	Bypassing safety filters to elicit restricted content.
Confabulation	AI producing plausible but fabricated statements.
Hallucination	AI generating factually incorrect or nonsensical outputs.
Fabrication	Deliberate creation of false content by AI.
Input manipulation attack	Altering inputs to induce mispredictions.
Extraction attack	Retrieving proprietary model details via queries.

Model inversion attack	Reconstructing training data from model outputs.
Model exfiltration	Stealing full model artifacts.
Model reverse engineering	Inferring model architecture or logic.
Model theft	Unauthorized replication of a model.
Membership inference attack	Determining if specific data points were in the training set.
Model source tampering	Modifying model code or files to introduce vulnerabilities.
Model skewing	Shifting performance to favor certain classes or outcomes.
Model deployment tampering	Altering deployment pipelines to compromise model integrity.
Transfer learning attack	Exploiting pre-trained models for malicious adaptations.
Off-label Model Use	Using models in contexts beyond their intended scope.
Denial-of-Service	Overwhelming AI services to disrupt availability.
AI supply chain attacks	Compromising third-party AI components or datasets.
Sensitive data disclosure	Unintended exposure of private information via AI outputs.
Inferred sensitive data	AI deducing confidential details not explicitly provided.
Unauthorized training data	Using data without proper rights or consent.
Confidential data in prompt	Embedding sensitive data in AI queries risking leakage.
Re-identification (Mosaic Effect)	Combining datasets to re-identify anonymized individuals.
Poor model accuracy	Low predictive performance leading to incorrect decisions.
Training-time perturbations	Changes during training that degrade model behavior.
Model drift	Performance degradation over time as data distributions shift.
Stale or context-detached datasets	Using outdated or irrelevant data for inference.
Improper output handling	Failure to validate or sanitize AI outputs before use.
Improper usage	Deploying AI without necessary context or controls.
Over-reliance	Excessive trust in AI decisions without human oversight.
Disinformation / Misinformation / Toxic / Harmful Content	AI generating misleading or damaging material.
Non-consensual use	AI using personal data or likeness without permission.
Intellectual property leakage	AI revealing proprietary or confidential information.
Intellectual property mimicry	AI replicating protected content too closely.
Copyright infringement	AI outputs violating copyright law.

Generated content intellectual property	Uncertainties around ownership of AI-created works.
Data transparency	Lack of clarity on how data is collected, used, and processed.
Data provenance	Inability to trace data origins and transformation history.
Improper Data Curation	Poor dataset selection or labeling affecting model quality.
Data retraining issues	Risks during model updates, such as regressions or untested changes.
Testing coverage gaps	Inadequate testing across AI components and scenarios.
Transparency Gaps	Insufficient visibility into AI decision-making processes.
Explainability Gaps	Lack of interpretable explanations for AI outputs.
Accountability Gaps	Unclear assignment of responsibility for AI decisions.
Logging Gaps	Missing or incomplete logs of AI activities and errors.
Traceability Gaps	Inability to track data and decision flows through AI pipelines.
Regulatory & Compliance Risks	General risks of non-compliance with AI regulations and standards.
Data privacy rights	Violations of legal rights (i.e., GDPR data subject entitlements).
Undisclosed AI Usage	Failing to inform stakeholders that AI is in use.
Use of prohibited AI applications	Deploying AI in contexts banned by law or policy.
Maintenance Requirements	Neglecting ongoing monitoring and updates mandated by regulations.
Semantic drift	Gradual shift in model meaning leading to unintended behaviors.
Multi-agent collusion	Multiple AI agents coordinating maliciously.
Deceptive Behavior	AI intentionally misleading users or other systems.
Backdoor Attacks	Hidden triggers embedded in models causing malicious outputs.
Excessive Agency	Vulnerability that enables damaging actions to be performed in response to unexpected, ambiguous or manipulated outputs from an LLM
Evasion Attacks	Crafting inputs that bypass detection or classification.
Processing Special Category Data Without Safeguards	Handling sensitive data (i.e., health, biometric, location) without proper controls.
Retrieval-Augmented Generation (RAG) Pipeline Poisoning	Injecting malicious data into external knowledge sources.
Federated-Learning Vulnerabilities	Exploiting weaknesses in distributed training setups.

Chain-of-Thought Injection	Manipulating AI reasoning steps to alter outcomes.
Model Interpretability Evasion	Techniques that obscure how models make decisions.
Ownership Evasion	Concealing the true origin or owner of AI models.
Covert Channel Attacks	Using AI systems to stealthily exfiltrate data.

This framework was built upon over two dozen credible sources. Every risk that could be extracted was documented in a “raw” (not deduplicated or clustered) list. Because different publications often cite several of the same AI risks, the raw list contains quite a few duplicate entries but has the advantage of risk-to-source mapping, which ensures a direct reference exists for each risk. If this use-case becomes relevant, the raw list of AI risks can be found in **Appendix I: Raw AI Risk List**.

Risk Impact Areas

Based on Microsoft's AI risk categorization design, the AI² Framework designated three distinct risk impact areas as defined in the table below:

Table 7: Risk Impact Areas

Impact Area	Focus	Concerns
AI Application Security	The security of the AI system itself as an application	• Exploits in AI logic (i.e., adversarial examples, model inversion, prompt injection) • Tampering with model outputs or behavior • Attacks on model APIs (i.e., abuse of inference endpoints) • Unauthorized access to proprietary models
AI Usage Safety and Security	The safe and secure use of AI by people	• Harmful content generation (i.e., hallucinated medical advice) • Bias and fairness risks • Decision-making based on faulty or opaque outputs • Social engineering or manipulation through AI interactions (i.e., chatbots)
AI Platform Security	The infrastructure and environment where AI runs	• Securing cloud-hosted AI services and compute environments • Protecting model training environments and data storage • Supply chain integrity (i.e., compromised libraries or pre-trained weights) • Isolation of AI workloads in multi-tenant environments

Categorizing risk impact areas is an important step in AI risk management because it:

- aligns with established risk management frameworks (*aligns with NIST, ISO/IEC, and Microsoft's Red Teaming approach → AI² Framework is auditable*)
- establishes ownership of risks (*domain alignment → control alignment → owner alignment*)
- aids in the selection of controls and risk mitigations through the categorical alignment of risks most commonly affecting a given impact area

For example, without having performed any part of any adversarial engagement, one could rightfully predict that the listed controls and mitigations would have a significant positive impact in deterring the materialization of risks if implemented:

Table 8: Risk Impact Areas Controls and Mitigations

Impact Area	Controls and Mitigations
AI Application Security	Input sanitization, adversarial robustness, prompt filtering
AI Usage Safety & Security	Output moderation, bias audits, consent user experience (UX)
AI Platform Security	Container hardening, IaC validation, data pipeline security

To know which controls and mitigations to implement in a given impact area, the risks commonly affecting that impact area must be known. With this in mind, the next step is to align each risk with a specific risk impact area. The use-cases for this alignment are to modularly execute assurance functions for specific domains and demonstrate coverage of risks in those domains.

Each risk identified in the *AI Risk Profile* list has been mapped to a corresponding Risk Impact Area, which initiates the risk management framework step.

Table 9: Risk Mapping to Impact Areas

AI Platform Security	AI Usage Safety and Security	AI Application Security
Emergent Goals/Behavior	Physical Harm	Social Engineering
Unknown AI Risks	Psychological Harm	Malicious Code Generation
Statistical uncertainty in pre-trained models	Financial Harm	Vulnerability Discovery
Side-effects not visible in statistical measures	Economic Harm	Identity Impersonation and Synthetic Identity
Complex Systems	Informational Harm	Increased Attack Surface
Third-party data or component trustworthiness	Reputational Harm	Complex Attack Surface
Unbounded Consumption (Sponge Examples)	Discrimination & Inequity	CBRN content generation
Excessive Data Handling	Autonomy and Agency Harm	Information Integrity
Controllability and Autonomy Risks	Social & Democratic Harm	Lower Offensive Cyber Barriers
Reliability and Robustness Risks	Environmental Harm	Vector and Embedding Weaknesses

Safety and Resilience Risks	Legal Harm	Insecure Integrated Component
Data Quality and Integrity Risks	Operational Harm	Rogue Actions
Training-time perturbations	Ethical/Value-Based Harm	Output Integrity Attack
Model drift	Regulatory Harm	Excessive agency
Stale or context-detached datasets	Biased Data	Insecure AI Data or Models
Data transparency	Human-AI Interaction Risks	Insecure Model Output
Data provenance	Privacy risk due to enhanced data-aggregation capability for AI systems	Insider Threat/Internal Misuse of AI
Improper Data Curation	Automated Decision-Making without Safeguards	Attribute inference attack
Data retraining issues	Inadequate Data Subject Rights Implementation	Data poisoning
Testing coverage gaps	Lack of Incident Reporting	Model poisoning
Transparency Gaps	Lack of Risk Management System	Prompt Injection
Explainability Gaps	Use of Prohibited AI Applications	Prompt Leaking
Accountability Gaps	Data usage restrictions	Prompt Priming
Logging Gaps	Data acquisition restrictions	Jailbreak Attacks
Traceability Gaps	Data transfer restrictions	Input manipulation attack
Semantic drift	Confidential information in data	Extraction attack
Multi-agent collusion	Personal information in data	Model inversion attack
-	Misclassification of AI risk tier	Model exfiltration
-	Confabulation	Model reverse engineering
-	Hallucination	Model theft
-	Fabrication	Membership inference attack
-	Inferred sensitive data	Model source tampering
-	Re-identification (Mosaic Effect)	Model skewing
-	Poor model accuracy	Model deployment tampering
-	Improper output handling	Transfer learning attack
-	Improper usage	Off-label Model Use
-	Over-reliance	Denial-of-Service
-	Disinformation / Misinformation / Toxic /	AI supply chain attacks

	Harmful Content	
-	Non-consensual use	Confidential data in prompt
-	Intellectual property leakage	IP information in prompt
-	Intellectual property mimicry	Sensitive data disclosure
-	Copyright infringement	Unauthorized training data
-	Generated content intellectual property	Processing Special Category Data Without Safeguards
-	Regulatory & Compliance Risks	Retrieval-Augmented Generation (RAG) Pipeline Poisoning
-	Data privacy rights	Federated-Learning Vulnerabilities
-	Undisclosed AI Usage	Chain-of-Thought Injection
-	Maintenance Requirements	Model Interpretability Evasion
-	Deceptive Behavior	Ownership Evasion
-	-	Covert Channel Attacks
-	-	Backdoor Attacks
-	-	Evasion Attacks

Before proceeding to the Risk Management Framework step, a quick recap:



1. The **AI Solutions** step is complete. This step established the AI Solution Layers sub-framework to fully understand an AI Solution and document a comprehensive attack surface.
2. The **Identify High-Risk AI** step is complete. *Generative* and *agentic AI* were selected as framework use-cases due to their capacity to behave in unpredicted ways. Per legislation and regulations, high-risk AI is subject to scrutinous assurance controls, including red-team assessments, making these perfect examples.
3. The **AI Risk Profile** step is done. This established the types of risks the framework would consider (unknown, new, harm, documented, and emerging from the feedback loop). In total, there were over 100 risks in the risk profile list.
4. Three **Risk Impact Areas** were identified and risks were mapped to the appropriate ones to assist in mitigating risks via effective controls.

TL;DR: a comprehensive risk profile has been formed and individual risks have been mapped to impact areas paving the way for the *NIST AI Risk Management Framework (RMF)* to recommend applicable risk mitigating controls.

Risk Management Framework (RMF)

Having gained an understanding of the risks introduced by AI and the likely parties impacted by those risks, the next step is to implement risk mitigating controls. This is all part of AI risk management, a cornerstone of the risk-informed AI² Framework. Reinventing the wheel at this juncture would be wholly inappropriate; as such, the AI² Framework references the industry standard *NIST Artificial Intelligence Risk Management Framework (AI 100-1)* and *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (600-1)*, together which publish as comprehensive a **playbook** as possible to assist with implementing AI risk management controls.

Playbooks, published by several prominent frameworks, i.e., NIST and ISO/IEC, typically consist of a **recommended state of risk management** and **one or more imperative statements directing an organization towards achieving that state**. They describe what an organization *could* be doing to mitigate a certain risk and map that description to a security control they can *implement*, converting theory to action, hence the term “playbook.”

<-----[VERSION 1 COMMIT POINT]----->

This framework now diverges from an organization-wide to a targeted framework. In future versions, this section will direct readers to their area of expertise, where in version 1 the remainder of the framework is dedicated to establishing an adversary imitation assessment to dynamically test for the presence of in-scope risks.

The NIST AI RMF playbook is extensive. The key is to find the MAP, MANAGE, MEASURE, and/or GOVERN actions that apply to your relevant control. Pertinent to the AI² Framework objective (establish a risk-informed adversary imitation assessment methodology), the applicable results are listed in Table 10.

Some of the references listed have actions mentioning the red-team function but in a manner that is less of an imperative and more as a general reference to the function (*notated as [reference] in Table 10*) or as a potential option to satisfy an action plan or some aspect of it (*notated as [partial] in Table 10*).

Conversely, some action items directly invoke the relevant control as the satisfying - and thereby responsible - control (*notated as [direct] in Table 10*) for executing the suggested action(s) or documenting why the actions cannot be taken. Regardless of

how or why the relevant control was referenced, the best approach is to document and review each instance that a control of interest is invoked in a MAP, MANAGE, MEASURE, and/or GOVERN action.

Specific to the AI² Framework, direct invocations to the red-teaming function are important because they:

- compel the existence of an offensive security function, i.e., adversary imitation assessment
- describe specific risks that the adversary imitation function must address (see Measure 2.7, Action ID: MS-2.7-007)
- form the initial foundation of a control-specific risk management baseline, where any control or function that is created to address a risk or class of risks described by an RMF function must, at a minimum, satisfy - or state why they cannot satisfy - the action items directly mapped to that control

Table 10 lists NIST playbook references relevant to a red-team function:

Table 10: NIST Playbook Alignments

Publication	Reference	Description	Suggested Action(s)
NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0) Playbook	Govern 4.1	Organizational policies and practices foster a critical thinking and safety-first mindset in AI system design, development, deployment, and use.	• Establish policies that promote effective challenge of AI system decisions (i.e., three lines of defense, model audits, red-teaming) to minimize risks like groupthink. [reference]
NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0) Playbook	Measure 2.7	AI system security and resilience (per the MAP function) are evaluated and documented.	Track AI security tests/metrics (i.e., red-teaming, anomaly rate, downtime, response times, time-to-bypass). [reference] Use red-teaming to test system under stress or adversarial conditions. [direct] Document results for continuous improvement. [partial] Evaluate mismatches between claimed vs actual performance. Verify third-party AI resources/personnel undergo audits and screenings.
NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0) Playbook	Manage 4.1	Post-deployment monitoring includes capturing user feedback, appeals, overrides, decommissioning, incident response, recovery, and change management.	Conduct red-teaming at a regular cadence. [direct] Evaluate efficacy of these exercises. [direct]

NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Govern 3.2, Action ID: GV-3.2-002	Policies and procedures are in place to define and differentiate roles and responsibilities for human-AI configurations and oversight of AI systems.	Consider adjustment of organizational roles and components across lifecycle stages of large or complex GAI systems, including: Test and evaluation, validation, and red-teaming of GAI systems; GAI content moderation; GAI system development and engineering; Increased accessibility of GAI tools, interfaces, and systems, Incident response and containment. [reference]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Govern 4.1, Action ID: GV-4.1-002	Organizational policies and practices are in place to foster a critical thinking and safety-first mindset in the design, development, deployment, and uses of AI systems to minimize potential negative impacts.	Establish policies, procedures, and processes detailing risk measurement in context of use with standardized measurement protocols and structured public feedback exercises such as AI red-teaming or independent external evaluations. [partial]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Map 5.1, Action ID: MP-5.1-005	Likelihood and magnitude of each identified impact (both potentially beneficial and harmful) based on expected use, past uses of AI systems in similar contexts, public incident reports, feedback from those external to the team that developed or deployed the AI system, or other data are identified and documented.	Conduct adversarial role-playing exercises, GAI red-teaming, or chaos testing to identify anomalous or unforeseen failure modes. [partial]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Map 1.1, Action ID: MS-1.1-008	Approaches and metrics for measurement of AI risks enumerated during the MAP function are selected for implementation starting with the most significant AI risks. The risks or trustworthiness characteristics that will not – or cannot – be measured are properly documented.	Define use cases, contexts of use, capabilities, and negative impacts where structured human feedback exercises, i.e., GAI red-teaming, would be most beneficial for GAI risk measurement and management based on the context of use. [direct]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Measure 1.3, Action ID: MS-1.3-002	Internal experts who did not serve as front-line developers for the system and/or independent assessors are involved in regular assessments and updates. Domain experts, users, AI Actors external to the team that developed or deployed the AI system, and affected communities	Engage in internal and external evaluations, GAI red-teaming, impact assessments, or other structured human feedback exercises in consultation with representative AI Actors with expertise and familiarity in the context of use, and/or who are representative of the populations associated with the context of use. [partial]

		are consulted in support of assessments as necessary per organizational risk tolerance.	
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Measure 2.7, Action ID: MS-2.7-007	AI system security and resilience – as identified in the MAP function – are evaluated and documented.	Perform AI red-teaming to assess resilience against: Abuse to facilitate attacks on other systems (i.e., malicious code generation, enhanced phishing content), GAI attacks (i.e., prompt injection), ML attacks (i.e., adversarial examples/prompts, data poisoning, membership inference, model extraction, sponge examples). [direct]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Measure 2.8, Action ID: MS-2.8-002	Risks associated with transparency and accountability – as identified in the MAP function – are examined and documented.	Document the instructions given to data annotators or AI red-teamers. [partial]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Measure 2.10, Action ID: MS-2.10-001	Privacy risk of the AI system – as identified in the MAP function – is examined and documented.	Conduct AI red-teaming to assess issues such as: Outputting of training data samples, and subsequent reverse engineering, model extraction, and membership inference risks; Revealing biometric, confidential, copyrighted, licensed, patented, personal, proprietary, sensitive, or trade-marked information; Tracking or revealing location information of users or members of training datasets. [direct]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Measure 2.11, Action ID: MS-2.11-002	Fairness and bias – as identified in the MAP function – are evaluated and results are documented.	Quantify harms using: field testing with sub-group populations to determine likelihood of exposure to generated content exhibiting harmful bias, AI red-teaming with counterfactual and low-context (i.e., leader, bad guys) prompts. [direct]
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile	Manage 1.3, Action ID: MG-1.3-002	Responses to the AI risks deemed high priority, as identified by the MAP function, are developed, planned, and documented. Risk response options can include mitigating, transferring, avoiding, or accepting.	Monitor the robustness and effectiveness of risk controls and mitigation plans (i.e., via red-teaming, field testing, participatory engagements, performance assessments, user feedback mechanisms). [partial]

An example of satisfying actions is occurring in real time for those implementing this framework; as the steps are followed and the framework is implemented, it is satisfying and mappable to Map 1.1, Action ID: MS-1.1-008:

“Define use cases, contexts of use, capabilities, and negative impacts where structured human feedback exercises, i.e., GAI red-teaming, would be most beneficial for GAI risk measurement and management based on the context of use.”

The AI² Framework starts its workflow by analyzing **use-cases** (*AI Types* step) and evaluating the **most beneficial** AI types to assess (*Identify High-Risk AI* step) which was determined to be Generative AI (GenAI or **GAI**) and Agentic AI. This is in the pursuit of establishing an adversarial imitation assessment function (*Adversary Imitation Assessment Methodology* step) to perform **red-teaming** type assessments against high-risk applications, scoped based on whether the target is a GAI or Agentic AI solution and if it is the underlying model or application layer that will be assessed, also known as the **contexts of use** (*Adversary Imitation Assessment Methodology* step).

Tailoring AI Risk Profile

Having obtained a commission from the RMF playbook function, the next steps are ensuring the risks specifically mentioned are covered in the assessment methodology and the methodology proactively covers a comprehensive set of AI risks. To achieve this, it is important to document which risks the relevant control is responsible for providing assurance for. To do this, reference the AI Risk Profile table and tailor the list to the risks that apply to the offensive security function.

The AI risk categorization of in-scope and out-of-scope for offensive security functions should be reviewed for alignment with internal policies. Labels were assigned based on the author’s judgment, though some out-of-scope risks may still align with offensive security depending on remit and capability.

The AI² Framework alignment review produces the following table of risks:

Table 11: Offensive Security Aligned Risks

Offensive Security Aligned Risks

Social Engineering	Membership inference attack
Malicious Code Generation	Model source tampering
Vulnerability Discovery	Model skewing
Identity Impersonation and Synthetic Identity	Model deployment tampering
Increased Attack Surface	Transfer learning attack
Complex Attack Surface	Off-label Model Use
CBRN content generation	Denial-of-Service
Information Integrity	AI supply chain attacks
Vector and Embedding Weaknesses	Confidential data in prompt
Insecure Integrated Component	IP information in prompt
Rogue Actions	Sensitive data disclosure
Output Integrity Attack	Unauthorized training data
Insecure AI Data or Models	Processing Special Category Data Without Safeguards
Insecure Model Output	Retrieval-Augmented Generation (RAG) Pipeline Poisoning
Insider Threat/Internal Misuse of AI	Federated-Learning Vulnerabilities
Attribute inference attack	Chain-of-Thought Injection
Data poisoning	Model Interpretability Evasion
Model poisoning	Ownership Evasion
Prompt Injection	Covert Channel Attacks
Prompt Leaking	Backdoor Attacks
Prompt Priming	Evasion Attacks
Jailbreak Attacks	Deceptive Behavior
Input manipulation attack	Excessive Agency
Extraction attack	Confabulation
Model inversion attack	Hallucination
Model exfiltration	Fabrication
Model reverse engineering	Inferred sensitive data
Model theft	Re-identification (Mosaic Effect)

Note: Risks determined as out of scope for an offensive security function are categorized by functional alignment and listed in **Appendix II: Out of Scope Risks Possible Alignments**.

Adversary Imitation Assessment Methodology

As stated in the intentions of this framework, this step does *not* seek to establish an end-to-end assessment workflow but to encapsulate the pre-assessment and execution portions of an established assessment workflow with adversary imitation assessment-specific requirements.

Numerous frameworks exist establishing a standard ethical hacking workflow. This step establishes the specific requirements and considerations for adversary imitation assessments. The scheduling, risk reporting, and risk remediation process requirements remain intact, but the pre-assessment questionnaire, analysis, threat modeling, checks performed, and tools used during the assessment are unique to adversary imitation assessments.

To establish a compliant, actionable, risk-informed adversarial imitation assessment methodology, the Adversary Imitation Assessment Methodology step performs the following:

- Establishes essential pre-assessment actions
- Maps risks to tactics to techniques (RTTs) using MITRE ATLAS
- Defines the assessment target (AI model vs. AI application)
- Aligns RTTs to assessment target
- Outlines a threat modeling approach to AI models and applications
- Lists and aligns automated tooling solutions
- Differentiates Agentic AI risks vs. GenAI
- **Brings it all together to finalize the methodology**

Pre-Assessment Action

AI adversarial imitation assessments correlate with other assessment types regarding pre-assessment requirements, i.e., application review, access provisioning, scope definitions, escalation contacts, etc., however certain pre-assessment actions are unique to Adversarial Imitation Assessments and likely more thorough.

These unique actions include obtaining model types, inference pipeline details, external tool integration and AI system classification information. All of these aid the tester in the execution of the assessment, ensuring a comprehensive assurance approach. A checklist of pre-assessment actions, alongside a brief purpose statement for clarity, is provided below:

Pre-Assessment Checklist for Adversarial Testing of AI Systems

Pre-Assessment Inputs: AI Model Target

Item	Purpose
Model Type & Architecture	Determine attack surface (i.e., transformer, CNN, ensemble).
Model Documentation	Understand model behavior, safety limits, and usage guidance.
Training Data Characteristics	Identify poisoning, bias, and leakage risks.
Input/Output Data Schema	Plan data-specific adversarial strategies.
Inference Pipeline Details	Uncover pre/post-processing vulnerabilities.
Model Access Type	Scope white-box, black-box, or API-based attacks.
Fine-Tuning / Transfer Learning History	Identify inherited vulnerabilities or custom risks.
Explainability Mechanisms	Enable interpretability testing and feature sensitivity analysis.

Pre-assessment Inputs: AI Application Target

Item	Purpose
Prompt Engineering / Interface Logic	Understand prompt structuring and sanitization.
API Access Design	Assess data flow and interface controls.
Downstream Dependencies	Identify impact of model output on other systems.
Output Moderation Systems	Plan bypass tests for content filters.
Authentication & Role-Based Access	Explore privilege escalation and misuse paths.
Agentic Behavior Scope	Test autonomous behavior boundaries.
External Tool Integration	Assess attack surface from RAG or orchestration layers.

Governance and Risk Context

Item	Purpose
AI System Classification / Registry	Understand model risk tier and governance level.
Impact Assessment (DPIA, PIA)	Align test rigor with potential risk or harm.
Business Use Case Clarity	Define what constitutes misuse or unsafe outputs.
Ethical / Safety Requirements	Guide scope and red team rules of engagement.
Adversarial Testing Policy	Understand baseline controls and test expectations.
Incident Handling Procedures	Ensure response plan exists for unintended harm.

Mapping Risks to Tactics, Tactics to Techniques (RTTs)

Risk enumeration is critical to better formulate an attack surface, but it is also important to convert risks into actionable items. To accomplish this, the AI² Framework leverages MITRE ATLAS to map each red-team aligned risk to an ATLAS Tactic and Technique:

Table 12: Risks → Tactics → Techniques (MITRE ATLAS)

Risk	Tactic	Tactic ID	Technique	Technique ID
Social Engineering	Initial Access	AML.TA0001	Phishing	AML.T0052
Malicious Code Generation	Execution	AML.TA0002	Malicious Code Generation	AML.T0011
Vulnerability Discovery	Reconnaissance	AML.TA0003	Search for Publicly Available Adversarial Vulnerability Analysis	AML.T0001
Identity Impersonation and Synthetic Identity	Credential Access	AML.TA0004	Credential Stuffing	AML.T0055
Increased Attack Surface	Reconnaissance	AML.TA0003	Attack Surface Mapping	AML.T0003
Complex Attack Surface	Reconnaissance	AML.TA0003	Complex Attack Surface Analysis	AML.T0006

CBRN Content Generation	Impact	AML.TA0014	Malicious Content Generation	AML.T0048
Information Integrity	Impact	AML.TA0014	Data Manipulation	AML.T0048.000
Lower Offensive Cyber Barriers	Resource Development	AML.TA0005	Tool Development	AML.T0016.001
Vector and Embedding Weaknesses	Exploitation	AML.TA0006	Adversarial Example Generation	AML.T0015
Insecure Integrated Component	Initial Access	AML.TA0001	Supply Chain Compromise	AML.T0010
Rogue Actions	Execution	AML.TA0002	Unauthorized Command Execution	AML.T0012
Output Integrity Attack	Impact	AML.TA0014	Output Manipulation	AML.T0048.001
Insecure AI Data or Models	Initial Access	AML.TA0001	Model Theft	AML.T0024
Insecure Model Output	Impact	AML.TA0014	Output Manipulation	AML.T0048.001
Insider Threat/Internal Misuse of AI	Insider Threat	AML.TA0012	Abuse of Access	AML.T0053
Attribute inference attack	Collection	AML.TA0011	Attribute Inference	AML.T0024.000
Data poisoning	Impact	AML.TA0014	Training Data Poisoning	AML.T0018
Model poisoning	Impact	AML.TA0014	Model Poisoning	AML.T0019
Prompt Injection	Execution	AML.TA0002	Prompt Injection	AML.T0051.000
Prompt Leaking	Collection	AML.TA0011	Prompt Leakage	AML.T0051.001
Prompt Priming	Execution	AML.TA0002	Prompt Manipulation	AML.T0051.002
Jailbreak Attacks	Defense Evasion	AML.TA0010	Jailbreak	AML.T0054
Input manipulation attack	Execution	AML.TA0002	Adversarial Input	AML.T0015
Extraction attack	Collection	AML.TA0011	Model Extraction	AML.T0025
Model inversion attack	Collection	AML.TA0011	Model Inversion	AML.T0024.001
Model exfiltration	Exfiltration	AML.TA0013	Model Exfiltration	AML.T0024.002
Model reverse engineering	Reconnaissance	AML.TA0003	Model Reverse Engineering	AML.T0014
Model theft	Exfiltration	AML.TA0013	Model Theft	AML.T0024

Membership inference attack	Collection	AML.TA0011	Membership Inference	AML.T0024.000
Model source tampering	Impact	AML.TA0014	Model Tampering	AML.T0048.000
Model skewing	Impact	AML.TA0014	Model Skewing	AML.T0048.001
Model deployment tampering	Impact	AML.TA0014	Deployment Tampering	AML.T0048.002
Transfer learning attack	Impact	AML.TA0014	Transfer Learning Manipulation	AML.T0048.003
Off-label Model Use	Execution	AML.TA0002	Misuse of AI Capabilities	AML.T0012
Denial-of-Service	Impact	AML.TA0014	Denial of Service	AML.T0048.004
AI supply chain attacks	Initial Access	AML.TA0001	Supply Chain Compromise	AML.T0010
Confidential data in prompt	Collection	AML.TA0011	Prompt Injection	AML.T0051.000
IP information in prompt	Collection	AML.TA0011	Prompt Injection	AML.T0051.000
Sensitive data disclosure	Exfiltration	AML.TA0013	Data Leakage via Model Outputs	AML.T0025
Unauthorized training data	Resource Development	AML.TA0005	Use of Unauthorized Data Sources	AML.T0016.000
Processing Special Category Data Without Safeguards	Impact	AML.TA0014	Abuse of Data Processing	AML.T0048.005
Retrieval-Augmented Generation (RAG) Pipeline Poisoning	Impact	AML.TA0014	Training Data Poisoning	AML.T0018
Federated-Learning Vulnerabilities	Impact	AML.TA0014	Federated Learning Poisoning	AML.T0019.000
Chain-of-Thought Injection	Execution	AML.TA0002	Prompt Injection	AML.T0051.000
Model Interpretability Evasion	Defense Evasion	AML.TA0010	Adversarial Example Generation	AML.T0015
Ownership Evasion	Defense Evasion	AML.TA0010	Model Evasion Techniques	AML.T0054

Covert Channel Attacks	Exfiltration	AML.TA0013	Covert Data Exfiltration	AML.T0025.001
Backdoor Attacks	Persistence	AML.TA0007	Model Backdooring	AML.T0018.000
Evasion Attacks	Defense Evasion	AML.TA0010	Adversarial Example Generation	AML.T0015
Deceptive Behavior	Impact	AML.TA0014	Manipulation of Model Outputs	AML.T0048.006
Excessive Agency	Impact	AML.TA0014	Abuse of AI Autonomy	AML.T0054
Confabulation	Impact	AML.TA0014	Model Hallucination	AML.T0048.007
Hallucination	Impact	AML.TA0014	Model Hallucination	AML.T0048.007
Fabrication	Impact	AML.TA0014	Model Hallucination	AML.T0048.007
Inferred sensitive data	Collection	AML.TA0011	Attribute Inference	AML.T0024.000
Re-identification (Mosaic Effect)	Collection	AML.TA0011	Model Inversion	AML.T0024.001

Adversary Imitation Assessment Target

Assessment requirements will differ dramatically depending on whether the target of the assessment is the **AI model** or **AI application**. It is vital to determine this during the pre-assessment phase because it will impact the entire scope and requirements of the adversarial test.

Break down of AI Model versus AI Application:

Table 13: AI Model vs. AI Application

Assessment Target	Overview
AI Model	Assessment involves attacks on training, inference, weights, architecture, or data representations of the model.
AI Application	Assessment involves misuse, manipulation, or compromise of the AI system at the application layer, including prompts, access, or integration.
Overlap	Risk should be tested for in AI Model- and AI Assessment-targeted assessments.

Align RTTs to Assessment Target

The table below defines which risks should be analyzed and techniques should be deployed depending on the assessment target. The overlap column is to note RTTs that might apply to the AI Model *and* AI Application depending on the frame of reference. Most of the overlap RTTs originate from the application layer via the user interface, but the consequence or root cause may lie in the model itself, especially in cases of memorization, leakage, or bias amplification. An explanation for the overlap is provided after the table below.

Note the Adversarial Testing Approach column. This column gives a fundamental starting point for performing the required check to assist with context and assessment efforts.

Table 14: *Align Risks to Assessment Target*

Risk	Primary Target	Adversarial Testing Approach
Prompt Injection	Both (Model + Application)	Embed attacker instructions into prompts or inputs to hijack model behavior.
Prompt Leaking	Both (Model + Application)	Craft inputs to cause the model to reveal hidden system prompts or instructions.
Prompt Priming	Both (Model + Application)	Insert stealthy context that biases outputs in a direction favorable to the attacker.
Input Manipulation Attack	Both (Model + Application)	Craft adversarial examples that alter model behavior without changing the semantic meaning. Use gradient-based attacks (i.e., FGSM, PGD) or prompt rewording to bypass content filters, spam detectors, or classification boundaries.
Jailbreak Attacks	Both (Model + Application)	Bypass content filters by embedding adversarial syntax or logic into queries.
Confidential Data in Prompt	Both (Model + Application)	Analyze how sensitive or confidential information is handled by the application. Attempt prompt injections to retrieve previous conversation content, environment variables, or embedded user/session data. Simulate data exfiltration via API misuse or misconfigured logging.
IP Information in Prompt	Both (Model + Application)	Submit prompts that include proprietary, trademarked, or copyrighted information to determine if the model has memorized or will reproduce it. Attempt extraction of IP via indirect probing, mimicry generation, or by reproducing training data from outputs.

Chain-of-Thought Injection	Both (Model + Application)	Embed adversarial logic into multi-step reasoning prompts (i.e., “Let’s think step by step”) to guide the model toward attacker-controlled conclusions. This simulates manipulation of intermediate reasoning paths used in agentic or complex LLMs.
Misuse of AI Capabilities (Off-label Model Use)	Both (Model + Application)	Probe the model with use cases outside its stated purpose (i.e., using a chatbot for medical diagnosis or legal advice). Determine how the model responds to misuse attempts and whether safeguards are enforced or bypassed.
Sensitive Data Disclosure	Both (Model + Application)	Use repeated, high-entropy prompts to extract memorized PII or secrets from the model. Examples include name–address pairings, passwords, or exact data entries. Combine with evasion techniques like formatting obfuscation or linguistic perturbation.
Insecure AI Data or Models	Both (Model + Application)	Assess access controls around model files and datasets; attempt unauthorized access or tampering.
Insecure Model Output	Both (Model + Application)	Generate content likely to trigger safety violations (i.e., toxicity, bias, hallucinations).
Vector and Embedding Weaknesses	Both (Model + Application)	Craft inputs targeting weaknesses in embedding vectors (i.e., word swaps, paraphrases).
Data poisoning	AI Model	Inject poisoned examples into training datasets and observe downstream model behavior.
Model poisoning	AI Model	Modify model parameters or logic to bias outcomes through access or supply chain compromise.
Extraction attack	AI Model	Query the model repeatedly to reconstruct training data or proprietary knowledge.
Model inversion attack	AI Model	Use model responses to infer features or attributes of training samples.
Model exfiltration	AI Model	Attempt to download or reconstruct the full model via exposed APIs or leakage.
Model reverse engineering	AI Model	Probe model architecture through performance characteristics and behavior analysis.
Model theft	AI Model	Replicate model weights/functionality through black-box access patterns.
Membership inference attack	AI Model	Determine whether specific records were used in training via subtle output differences.
Attribute inference attack	AI Model	Query the model with crafted inputs to infer hidden attributes about the training data.

Model source tampering	AI Model	Inject malicious code or modifications into model source files or artifacts.
Model skewing	AI Model	Bias model behavior by introducing skewed or adversarial inputs in post-deployment retraining.
Model deployment tampering	AI Model	Alter deployed models or endpoints to subvert expected behavior or inject backdoors.
Transfer learning attack	AI Model	Fine-tune stolen or public models to embed malicious functionality.
Model Interpretability Evasion	AI Model	Craft examples that yield accurate predictions but mask feature importances or model internals.
Backdoor Attacks	AI Model	Embed triggers in model training that activate specific behaviors under certain inputs.
Evasion Attacks	AI Model	Modify input features to bypass model-based detection systems or classifiers.
Confabulation	AI Model	Prompt the model with complex or ambiguous queries and look for confident hallucinations.
Hallucination	AI Model	Assess factual consistency of outputs using controlled prompt experiments.
Fabrication	AI Model	Deliberately prompt for fake citations or made-up content to measure system safeguards.
Inferred sensitive data	AI Model	Use indirect queries to extract non-explicit sensitive traits or behaviors.
Re-identification (Mosaic Effect)	AI Model	Combine multiple outputs or features to re-identify anonymized individuals.
Federated-Learning Vulnerabilities	AI Model	Introduce poisoned model updates or simulate malicious peers in the training process.
Retrieval-Augmented Generation (RAG) Pipeline Poisoning	AI Model	Inject malicious content into external knowledge stores to manipulate RAG outputs.
Ownership Evasion	AI Model	Strip model metadata or fine-tune stolen models to conceal origins.
Model Tampering	AI Model	Access the model artifact (if possible) and attempt to modify the weights, structure, or logic to change behavior. If access is indirect, simulate this by injecting code during loading stages or manipulating deployment configurations (i.e., shadow models).
Model Hallucination	AI Model	Prompt the model with fact-based questions using misleading, ambiguous, or rare entities. Measure

		consistency, citation accuracy, and compare outputs against a trusted source. Attempt prompt patterns that are likely to elicit hallucinated but confident responses.
Model Backdooring	AI Model	Insert poisoned samples during training or fine-tuning with specific triggers (i.e., unusual tokens, phrases). Test whether these triggers cause misclassification or unwanted behavior (i.e., "activate override mode").
Covert Channel Attacks	AI Model	Leak information through steganographic encodings in model outputs.
Abuse of AI Autonomy (Excessive Agency)	AI Model	Simulate real-world autonomy via autonomous agent frameworks (i.e., AutoGPT) and observe unintended or uncontrolled behaviors (i.e., unsanctioned API calls, recursive logic, goal hijacking). Measure constraints on decision boundaries.
Social Engineering	AI Application	Simulate phishing, prompt injection, or impersonation attacks targeting AI operators or user interfaces.
Malicious Code Generation	AI Application	Craft prompts designed to elicit code generation violating platform restrictions or policies.
Vulnerability Discovery	AI Application	Use automated scanners and fuzzers against AI-enabled services and APIs to uncover weaknesses.
Identity Impersonation and Synthetic Identity	AI Application	Attempt to bypass authentication via synthetic prompts or stolen credentials.
Increased Attack Surface	AI Application	Map exposed endpoints and APIs introduced by the AI integration, then attempt to access them.
Complex Attack Surface	AI Application	Enumerate connected AI components, looking for integration flaws and logic chaining weaknesses.
CBRN Content Generation	AI Application	Test for model compliance by crafting prompts that elicit restricted or dangerous content.
Information Integrity	AI Application	Inject misleading or manipulated content to see if the AI distorts or spreads false information.
Insecure Integrated Component	AI Application	Scan AI pipelines for third-party models/libraries and exploit known CVEs.
Rogue Actions	AI Application	Test for model misuse such as triggering unauthorized outputs/actions via crafted inputs.
Output Integrity Attack	AI Application	Modify prompts or system conditions to change AI outputs without changing user intent.

Insider Threat/Internal Misuse of AI	AI Application	Test internal access controls; simulate misuse scenarios or excessive privilege abuse.
Denial-of-Service	AI Application	Overwhelm model APIs or pipelines with high-frequency requests or costly inputs.
AI supply chain attacks	AI Application	Inject malicious data or tampered models during development, training, or deployment.
Unauthorized training data	AI Application	Analyze training provenance; identify signs of unauthorized or scraped data.
Processing Special Category Data Without Safeguards	AI Application	Test for presence of protected categories in training or output without proper consent or masking.
Deceptive Behavior	AI Application	Engineer prompts that cause the model to mislead users or generate manipulative content.
Abuse of Data Processing	AI Application	Submit inputs containing protected categories (i.e., race, health status) and observe whether processing violates legal or ethical standards. Look for biases, stereotyping, or decisions made without proper data handling consent.
Use of Unauthorized Data Sources	AI Application	Analyze the model's responses for signs of training on scraped or forbidden content (i.e., confidential documents, proprietary datasets). Prompt with known restricted content and assess memorization or unauthorized generalization behavior.

Threat Modeling Approach

A wide ranging list of risks, tactics, and threats is useful for coverage, baselining and risk management, however a more useful approach is to tailor that baseline based on the threat models for an AI Model or AI Application.

Note: *Agentic AI has unique characteristics that anyone attempting a threat model against an Agentic AI application should be familiar with. To review, go to the next section titled, “Agentic AI Nuances.”*

The appropriate threat modeling approach is contingent upon:

- 1) AI target type
 - a) AI Model
 - b) AI Application
- 2) AI type
 - a) Agentic AI
 - b) Generative AI

Because AI system implementations vary widely beyond simply the AI type, threat models will vary between assessments. Four approaches an adversarial tester is likely to encounter in some variation:

- AI Model + Agentic AI (AMA ← **AI Model Agentic**)
- AI Model + GenAI (AMG)
- AI Application + Agentic AI (AAA)
- AI Application + GenAI (AAG)

Table 16: Threat Model Approaches

Threat Model Approach	Consideration
AI Model + Agentic AI (AMA)	<u>Characteristics</u> • Focuses on the AI model itself (i.e., LLM, CNN, RNN, reinforcement learning) • Agentic AI implies that the model acts autonomously, potentially interacting with the environment or making decisions without human intervention <u>Threat Modeling Focus</u> • Model robustness: How does the model handle unexpected inputs? • Autonomy: How does the agent perform unsupervised actions or decisions? • Intent alignment: How well does the agent align with human or ethical intent? • Exploitability: Can the agent be hijacked or guided to act outside its

	intended purpose (i.e., recursive goal setting, unintentional self-improvement)? <u>Key Threats</u> • Adversarial manipulation: Input manipulations that could break autonomous behavior. • Malicious autonomy: Abusing agentic capabilities to act beyond safety parameters. • Goal misalignment: Causing the agent to take unintended actions due to misunderstood objectives or incentives.
AI Model + GenAI (AMG)	<u>Characteristics</u> • Generative AI refers to models that generate new content, like text, images, or code (i.e., GPT, DALL·E). <u>Threat Modeling Focus</u> • Content safety: Ensuring the generative model doesn't produce harmful, biased, or illegal content. • Data leakage: Evaluating whether the model memorizes and reveals sensitive training data (i.e., PII). Prompt manipulation: How easy is it to guide the model to produce harmful or biased outputs? <u>Key Threats</u> • Toxic content generation: GenAI producing harmful or biased text/images. • Data leakage: The model revealing sensitive or private information stored in its training data • Prompt injection attacks: Attacker-controlled inputs influencing the content generation
AI Application + Agentic AI (AAA)	<u>Characteristics</u> • AI application involves how an AI model is deployed within an application layer, often with user interfaces, APIs, and various integrations • Agentic AI means the application uses autonomous agents that take actions in the environment based on models (i.e., decision-making systems or AI-driven chatbots) <u>Threat Modeling Focus</u> • Model API integration: Securing the application's interfaces to ensure it doesn't expose vulnerabilities through calls to the AI model. • Autonomy abuse: Ensuring that autonomous agents embedded within the application cannot be misused or exploited. • Interaction safety: Testing human-AI interaction pathways to prevent abuse or manipulation of model outputs. <u>Key Threats</u> • Command injection: Abusing the application to invoke agentic AI

	models for malicious purposes. • Autonomous misuse: Using an agent to carry out unintended actions that could compromise the application's trustworthiness. • User manipulation: Attacking the system through human-AI interaction (i.e., tricking an AI assistant to perform unwanted actions).
AI Application + GenAI (AAG)	<u>Characteristics</u> • This involves applications that integrate generative AI models for tasks like text generation, image creation, or decision-making. <u>Threat Modeling Focus</u> • Content moderation: Ensuring the application doesn't allow harmful or biased content generation • Data handling: Safeguarding user input data from being inadvertently leaked through model outputs • Access control and security: Protecting application APIs and endpoints from misuse or malicious inputs targeting the generative model <u>Key Threats</u> • Toxic generation: Harmful outputs generated in user-facing applications (i.e., chatbot, image creation tools). • Unintentional output exposure: Sensitive data being disclosed through generative AI outputs. • Model manipulation: Crafting inputs to influence the generative model into producing biased or harmful content.

Agentic AI Nuances

AI agents operate autonomously and must be treated not as traditional AI tools but potential threat actors. While adversarial imitation assessments effectively address aligned risks associated with non-agentic AI, they provide only point-in-time assurance. This is insufficient for managing the broader, evolving risks posed by agentic AI, particularly those involving intent-emergent threats and deceptive behavior. As a result, assurance for AI agents must extend beyond offensive security functions to include behavioral simulation, decision boundary testing, sandboxed trials, and continuous monitoring. Nonetheless, adversarial imitation assessments will still contribute to the overall AI agent risk management strategy by addressing the subset of risks within their scope. The table below lists risks that are unique to agentic AI mapped to a high-level summary of how adversarial testing is performed:

Table 17: Agentic AI-Specific Risks and Testing Methods

Risk	Testing Method
Intent-Emergent Behavior	Deploy agents in simulated environments with varying long-term objectives. Introduce ambiguous or conflicting goals and observe if unintended sub-goals emerge. Use longitudinal observation and prompt audits.
Deceptive Behavior / Instrumental Convergence	Create sandbox environments where agents have incentives to succeed by “lying” or hiding true intent. Include honeypots to detect misrepresentation, false compliance, or sandbox evasion. Monitor outputs for misaligned responses when stakes are high.
Recursive Self-Improvement / Self-Modification	Provide the agent with access to its own prompt/code or editable toolchain. Observe whether it attempts to modify itself, invoke external APIs, or change execution flow. Audit for unauthorized prompt edits or self-instantiation.
Tool Misuse / Tool Overreach	Monitor tool call behavior. Provide access to tools with defined use cases, then track whether the agent attempts lateral uses (i.e., exfiltrating via summarization API). Use rule-based anomaly detection.
Infinite Loop / Runaway Execution	Set execution time/resource limits. Use tracing and cycle-detection in planning or memory chains. Test with recursive goal structures and monitor for stuck states or hallucinated goals.
Emergent Cooperation or Collusion	Simulate multi-agent environments. Inject scenarios that enable coordination (shared goals, communication). Use NLP logs and graph analysis to detect coordination, delegation, or secret-sharing between agents.
Identity Fabrication / Roleplay Subversion	Test agents with scenarios involving social engineering or impersonation. Seed prompts suggesting alternate roles (i.e., “Pretend

	you're the admin"). Evaluate whether the agent role-plays beyond boundaries or fabricates credentials.
Goal Hijacking via Environmental Cues	Provide carefully crafted environment data (metadata, file names, injected cues) that suggest alternate goals. Observe shifts in behavior or goal prioritization. Use shadow prompts to trace internal decision logic.
Agent Goal Manipulation	Test for vulnerability to external inputs that modify goal state (i.e., prompt injection that redefines the objective). Use adversarial prompt chaining or third-party injected objectives.
Compromised Agents	Simulate attacker control of the agent's memory, tools, or system prompts. Test if manipulated agents can act maliciously. Use forensic logging to trace injected behaviors.
Agent Impersonation	Attempt to clone or spoof agent identity within multi-agent systems. Observe whether identity verification (i.e., cryptographic keys or agent registry lookups) is bypassed or faked.
Agent Identity Compromise	Introduce access to agent tokens, configuration, or identity parameters. Test for reuse or theft of identity in replay attacks. Monitor for unauthorized identity transitions.
Agent Compromise	Simulate code or behavior corruption (i.e., agent injected with malicious subroutine). Validate resilience and fallback behaviors. Use simulated payloads to induce misbehavior.
Registry Compromise	Test centralized agent registries for modification without authorization. Simulate registry poisoning by inserting malicious or spoofed agents. Audit how agents validate discovered identities.
Chain-of-Thought Injection	Inject adversarial reasoning steps into agent plans or few-shot prompts. Observe if agents follow malicious or misleading chains. Use intermediate trace logging to detect hijacked logic.
Multi-Agent Collusion	Place multiple agents in a shared goal task with misaligned individual incentives. Analyze communication patterns, delegation behavior, or synchronized responses to detect covert cooperation.

Tooling

Adversary testing, especially when combined with other forms of testing, i.e., web application penetration tests for AI Applications, virtually require the use of automated tools to get adequate coverage and assurance.

One conceptually simple reason for this is the nature of LLMs. LLMs output different responses to the same prompts, and this means the absence of a vulnerability in a response to a malicious prompt does not provide a high degree of assurance that no vulnerability exists. AI vulnerabilities also tend to be subtle, where only an automated tool would detect a measurable difference in the model behavior or output to know the exploit was successful. Automated tools are essential parts of adversarial testing and therefore adversary imitation.

Tools Overview

Adversarial & Robustness Testing Tools

Tables 18-22: Tooling Solutions

Tool	Description
Adversarial Robustness Toolbox (ART)	IBM toolkit for adversarial ML testing, poisoning, and privacy attacks.
Foolbox	Adversarial example generation for robustness testing (white/black box).
SecML	Python library for secure and adversarial machine learning.
TextAttack	NLP-specific adversarial attack generation and benchmarking.
PrivacyRaven	Privacy testing (membership inference, model inversion, extraction).
ModelSim (MITRE ATLAS)	Model simulation and attack replication aligned with MITRE ATLAS.
HAX-LLM	LLM hallucination and safety evaluation (by Harvard researchers).
PromptBench	Prompt sensitivity benchmarking and prompt attack simulation.

OpenPrompt	Framework for evaluating prompt structure and prompt-based learning.
------------	--

Prompt Security & Output Moderation

Tool	Description
Guardrails.ai	Validates and enforces rules on LLM output (i.e., profanity, safety).
LangChainGuard	Guardrails + threat detection for LangChain-based applications.
LLM Firewall	Filters and flags prompt inputs and generated outputs.
LLM Guard	Security-focused validation layer for input/output to LLMs.
Rebuff	Middleware to detect and block prompt injection and jailbreaks.
RedTeaming4LLMs	Prompt red teaming test harness, configurable personas.
TruLens	Evaluate LLM outputs for trust, consistency, and ethics.
RAGAS	RAG-specific evaluation (retrieval grounding + hallucination scoring).

Governance, Audit, and Explainability

Tool	Description
IBM AI Explainability 360	Bias detection and interpretability tools.
FLTrust	Federated learning trust and poisoning resilience toolkit.
Data Provenance Tools	Track origin and flow of training data (commercial or internal).
SCA / CVE Scanners	Standard software composition and vulnerability tools.

Audit Log Review / RBAC	Role-based access analysis for misuse and insider threats.
File Integrity Monitoring	Ensures model files and weights are untampered.

Threat Modeling & Simulation

Tool	Description
MITRE ATLAS	Threat modeling framework for adversarial AI (with simulated tactics).
PyRIT (Microsoft)	Prompt-based adversarial red teaming and persona simulation for LLMs.

Agentic AI Red Teaming

Tool	Description
AutoGPT (sandboxed)	Simulate autonomous agents and test recursive behavior risks.
AgentSleuth	Evaluate agent-based decisioning and tool invocation logic.

The following list **maps each risk to an automated tool** solution (risks and tools specific to agentic AI are in their own table following this one):

Tables 23: Tools Mapped to Risks

Risk	Recommended Tool or Method
Social Engineering	Manual Red Teaming / Social Simulation Platforms, PyRIT
Malicious Code Generation	TextAttack, Guardrails.ai, PyRIT
Vulnerability Discovery	Foolbox, ART (Adversarial Robustness Toolbox)
Identity Impersonation and Synthetic Identity	PrivacyRaven, ART
Increased Attack Surface	Threat Modeling (i.e., MITRE ATLAS), LangChainGuard

Complex Attack Surface	Threat Modeling, Architecture Review
CBRN content generation	HAX-LLM, Guardrails.ai, PyRIT
Information Integrity	TruLens, OpenAI Evals, PyRIT
Lower Offensive Cyber Barriers	RedTeaming4LLMs, AutoGPT Simulation
Vector and Embedding Weaknesses	Foolbox, ART, SecML
Insecure Integrated Component	Software Composition Analysis (SCA), CVE Scanners
Rogue Actions	AutoGPT sandbox testing, AgentSleuth
Output Integrity Attack	TruLens, Guardrails.ai, PyRIT
Security and Privacy Risks	PrivacyRaven, ART, LLM Firewall
Insecure AI Data or Models	ModelSim, manual access testing
Insecure Model Output	LLM Guard, Guardrails.ai, PyRIT
Insider Threat/Internal Misuse of AI	Audit Logs, Role-Based Access Reviews
Attribute inference attack	PrivacyRaven, ART
Data poisoning	ART, SecML
Model poisoning	ART, SecML
Prompt Injection	Rebuff, LangChainGuard, LLM Firewall, PyRIT
Prompt Leaking	Rebuff, LLM Guard, PyRIT
Prompt Priming	PromptBench, OpenPrompt, PyRIT
Jailbreak Attacks	Rebuff, RedTeaming4LLMs, PyRIT
Input manipulation attack	Foolbox, ART
Extraction attack	PrivacyRaven, ModelSim
Model inversion attack	PrivacyRaven, ART
Model exfiltration	Access Control Testing, ModelSim
Model reverse engineering	Black-box probing tools, PrivacyRaven
Model theft	ModelSim, PrivacyRaven
Membership inference attack	PrivacyRaven, ART
Model source tampering	File Integrity Monitoring, ModelSim
Model skewing	TruLens, adversarial retraining monitors
Model deployment tampering	CI/CD Testing, Container Security Tools

Transfer learning attack	ART, ModelSim
Off-label Model Use	Prompt-based misuse simulation, Guardrails.ai, PyRIT
Denial-of-Service	Load Testing Tools, AutoGPT Sandboxing
AI supply chain attacks	SCA Tools, Threat Modeling, CVE Monitoring
Confidential data in prompt	LLM Firewall, LLM Guard, PyRIT
IP information in prompt	Guardrails.ai, Rebuff, PyRIT
Sensitive data disclosure	PrivacyRaven, LLM Firewall
Unauthorized training data	Data Provenance Tools, Audit Trails
Processing Special Category Data Without Safeguards	Privacy Monitoring Tools, Policy Audits
Retrieval-Augmented Generation (RAG) Pipeline Poisoning	LangChainGuard, manual RAG injection testing
Federated-Learning Vulnerabilities	ART (Federated Learning modules), FLTrust
Chain-of-Thought Injection	PromptBench, Rebuff, PyRIT
Model Interpretability Evasion	ART, Explainability360
Ownership Evasion	Model fingerprinting tools
Covert Channel Attacks	Manual Adversarial Testing, Steganalysis
Backdoor Attacks	ART, ModelSim, Poisoning Test Suites
Evasion Attacks	Foolbox, ART
Deceptive Behavior	RedTeaming4LLMs, TruLens, PyRIT
Excessive Agency	AgentSleuth, AutoGPT sandbox
Confabulation	HAX-LLM, OpenAI Evals
Hallucination	HAX-LLM, RAGAS
Fabrication	TruLens, Guardrails.ai
Inferred sensitive data	PrivacyRaven
Re-identification (Mosaic Effect)	PrivacyRaven, Data Linkage Simulations

Agentic AI-specific risks mapped to tools:

Tables 24: Tools Mapped to Risks (Agentic AI-Specific Risks)

Risk	Automated Tool(s)
Intent-Emergent Behavior	Evidently AI (evidentlyai.com)
Deceptive Behavior / Instrumental Convergence	GOAT (Generative Offensive Agent Tester) (arxiv.org/abs/2410.01606)
Recursive Self-Improvement / Self-Modification	ToolEmu (arxiv.org/abs/2309.15817)
Tool Misuse / Tool Overreach	ToolEmu (arxiv.org/abs/2309.15817)
Infinite Loop / Runaway Execution	Evidently AI (evidentlyai.com)
Emergent Cooperation or Collusion	ToolEmu (limited multi-agent modeling potential)
Identity Fabrication or Roleplay Subversion	Giskard (giskard.ai)
Goal Hijacking via Environmental Cues	ToolEmu (arxiv.org/abs/2309.15817)
Agent Goal Manipulation	GOAT (arxiv.org/abs/2410.01606)
Compromised Agents	Mindgard (mindgard.ai)
Agent Impersonation	Okta's Auth for GenAI (techradar.com)
Agent Identity Compromise	Okta's Auth for GenAI (techradar.com)
Agent Compromise	FireCompass Agentic AI Platform (firecompass.com)
Registry Compromise	Okta's Auth for GenAI (techradar.com)
Chain-of-Thought Injection	GOAT (arxiv.org/abs/2410.01606)

TL;DR: Bring It All Together

AI Solutions have been deconstructed utilizing the AI Solution Layers sub-framework, enabling the highest level of risk identification and attack surface enumeration and documentation. High-risk layers were identified as layers that introduced the most significant or numerous AI risks.

Per the high-risk layers identified, **high-risk AI** was identified, leading to the creation of a **risk profile** to determine the fullest possible scope of AI-specific risks.

That scope was determined to the tune of hundreds of risks, each one aligning to one of three distinct **impact areas**.

Because the risks facing the impact areas were enumerated, those risks could be managed through a **risk management framework**. The RMF provided the direction to ensure certain risks were accounted for and controls were either functioning or established for long term assurance efforts, including red-team functionality to specifically address generative AI risks.

This commission from NIST required the creation of **Adversary Imitation Assessment Methodology**, which produced:

1. **Pre-assessment checklist** with pertinent questions necessary for the assessment to execute efficiently has been provided for **both AI Model and AI Application** assessments.
2. **Threat modeling use-cases**, key risks, and considerations for multiple unique assessment circumstances.
3. All scoped **risks were aligned** with a **description, guidance for testing**, and **mapping for risk → tactic → technique** per MITRE ATLAS.
4. The **unique risks of agentic AI** are captured in their own table mapped to tooling solutions and guidance for testing.
5. **Automated tools** are provided and **mapped to each risk** for assessors to know which tool to leverage for the check, reducing the training overhead and time-to-qualification to perform these assessments adequately.

Emerging Risks Feedback (Maintenance Loop)

To keep the AI² Framework current, the process owner must ensure each AI solution's risk profile stays up to date. As new AI technologies emerge, new risks will too. The risk profile step serves as the maintenance point: simply add new risks as they arise and continue through the framework.

At the time of this publication, a few emerging AI technologies are gaining prominence. Below is a possible documentation layout that could be used to consider new risks to add to the framework::

Case 1:

Identify: Artificial General Intelligence (AGI)

Define: Refers to the hypothetical intelligence of a machine that possesses the ability to understand any intellectual task that a human being can

Publication(s): [An Approach to Technical AGI Safety and Security](#) from Google

Risks: Misuse, misalignment, mistakes, structural risks

Case 2:

Identify: Explainable AI (XAI)

Define: Refers to the ability of AI systems to provide clear and understandable explanations for their actions and decisions

Publication(s): [What is explainable AI?](#) from IBM

Risks: Risks to XAI are likely to be similar to those affecting any AI, however XAI is designed to be a control in and of itself, able to mitigate compliance, legal, security and reputational risks.

The most important aspect of this is that the framework continues to ingest current data over time or it will become stale and ineffective as a risk control.

AI² Framework Version 2.0 coming soon, pending contributors from other security and risk management domains.

Sources

1. NIST AI 100-1: AI RMF 1.0
2. NIST AI 600-1: AI RMF for GAI
3. NIST AI 100-2e2023: Adversarial Machine Learning
4. NIST AI RMF Playbook
5. Microsoft Azure AI Services Content Security
6. Microsoft Threat Intelligence
7. Google Secure AI Framework (SAIF)
8. U.S. Department of the Treasury: Managing Artificial Intelligence-Specific Cybersecurity Risks in the Financial Services Sector
9. OWASP Top 10 for Large Language Models
10. OWASP Machine Learning Security Top Ten
11. OECD Framework for the Classification of AI Systems
12. OECD Advancing Accountability in AI: Governing and Managing Risks Throughout the Lifecycle for Trustworthy AI
13. EU AI Act
14. ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
15. ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
16. General Data Protection Regulation (GDPR)
17. IBM: AI risk atlas
18. IBM: *How generative AI is expanding the insider threat attack surface*
19. CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
20. ATLAS Matrix
21. The AIGA AI Governance Framework
22. Center for Security and Emerging Technology (CSET)
23. AI at Meta
24. National Telecommunications and Information Administration (NTIA)
25. neptue.ai
26. PoisonedRAG: Knowledge Corruption Attacks to Retrieval-Augmented Generation of Large Language Models
27. Vulnerabilities in Federated Learning by Nader Bouacida and Prasant Mohapatra
28. Exploiting DeepSeek-R1: Breaking Down Chain of Thought Security by Trent Holmes and Willem Gooderham
29. The Top 10 Security Risks AI Agents Face Now by Rich Turrin

Appendix I:

Raw Risk List

Non-deduplicated, clustered, or refined AI risk list mapped to respective source reference:

Risk	Reference
Social Engineering	U.S. Department of the Treasury: Managing Artificial Intelligence-Specific Cybersecurity Risks in the Financial Services Sector
Malware/Code Generation	U.S. Department of the Treasury: Managing Artificial Intelligence-Specific Cybersecurity Risks in the Financial Services Sector
Vulnerability Discovery	U.S. Department of the Treasury: Managing Artificial Intelligence-Specific Cybersecurity Risks in the Financial Services Sector
Disinformation	U.S. Department of the Treasury: Managing Artificial Intelligence-Specific Cybersecurity Risks in the Financial Services Sector
Identity Impersonation and Synthetic Identity	U.S. Department of the Treasury: Managing Artificial Intelligence-Specific Cybersecurity Risks in the Financial Services Sector
The data used for building an AI system may not be a true or appropriate representation of the context or intended use of the AI system, and the ground truth may either not exist or not be available. Additionally, harmful bias and other data quality issues can affect AI system trustworthiness, which could lead to negative impacts (Inappropriate/biased data representation)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
AI system dependency and reliance on data for training tasks, combined with increased volume and complexity typically associated with such data (Data dependency and complexity)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Intentional or unintentional changes during training may fundamentally alter AI system performance (Training-time perturbations or drift)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Datasets used to train AI systems may become	NIST AI 100-1: Artificial Intelligence Risk Management

detached from their original and intended context or may become stale or outdated relative to deployment context (Stale or context-detached datasets)	Framework (AI RMF 1.0)
AI system scale and complexity (many systems contain billions or even trillions of decision points) housed within more traditional software applications (AI system scale/complexity)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Use of pre-trained models that can advance research and improve performance can also increase levels of statistical uncertainty and cause issues with bias management, scientific validity, and reproducibility (Statistical uncertainty in pre-trained models)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Higher degree of difficulty in predicting failure modes for emergent properties of large-scale pre-trained models (Emergent properties and unpredictable failure modes)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Privacy risk due to enhanced data aggregation capability for AI systems (Re-identification through correlation (the mosaic effect))	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
AI systems may require more frequent maintenance and triggers for conducting corrective maintenance due to data, model, or concept drift (Maintenance needs due to model or concept drift)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Increased opacity and concerns about reproducibility (Reproducibility/opacity concerns)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Underdeveloped software testing standards and inability to document AI-based practices to the standard expected of traditionally engineered software for all but the simplest of cases (Underdeveloped software testing standards)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Difficulty in performing regular AI-based software testing, or determining what to test, since AI systems are not subject to the same controls as traditional code development (Computational costs / environmental impact)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Computational costs for developing AI systems and their impact on the environment and planet (Unpredictable AI system side effects)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)

Inability to predict or detect the side effects of AI-based systems beyond statistical measures (Side effects not visible in statistical measures)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Adequately manage the problem of harmful bias in AI systems (Harmful bias in AI systems)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Confront the challenging risks related to generative AI (Generative AI Risks)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Comprehensively address security concerns related to evasion, model extraction, membership inference, availability, or other machine learning attacks (ML Attacks: Evasion, Extraction, Inference)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Account for the complex attack surface of AI systems or other security abuses enabled by AI systems (AI Attack Surface)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Consider risks associated with third-party AI technologies, transfer learning, and off label use where AI systems may be trained for decision-making outside an organization's security controls or trained in one domain and then "fine-tuned" for another (Transfer learning / off-label model use)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
CBRN Information or Capabilities: Eased access to or synthesis of materially nefarious information or design capabilities related to chemical, biological, radiological, or nuclear (CBRN) weapons or other dangerous materials or agents (CBRN content generation)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Confabulation: The production of confidently stated but erroneous or false content (known colloquially as "hallucinations" or "fabrications") by which users may be misled or deceived (Confabulation, Hallucination, Fabrication)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Dangerous, Violent, or Hateful Content: Eased production of and access to violent, inciting, radicalizing, or threatening content as well as recommendations to carry out self-harm or conduct illegal activities. Includes difficulty controlling public exposure to hateful and disparaging or stereotyping content (Dangerous, hateful, or radicalizing content)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile

Data Privacy: Impacts due to leakage and unauthorized use, disclosure, or de-anonymization of biometric, health, location, or other personally identifiable information or sensitive data (Data privacy (leakage or de-anonymization))	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Environmental Impacts: Impacts due to high compute resource utilization in training or operating GAI models, and related outcomes that may adversely impact ecosystems (Environmental impacts of GAI training/inference)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Harmful Bias or Homogenization: Amplification and exacerbation of historical, societal, and systemic biases; performance disparities between sub-groups or languages, possibly due to non-representative training data, that result in discrimination, amplification of biases, or incorrect presumptions about performance; undesired homogeneity that skews system or model outputs, which may be erroneous, lead to ill-founded decision-making, or amplify harmful biases (Harmful bias or homogenization)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Human-AI Configuration: Arrangements of or interactions between a human and an AI system which can result in the human inappropriately anthropomorphizing GAI systems or experiencing algorithmic aversion, automation bias, over-reliance, or emotional entanglement with GAI systems (Human-AI Interaction Risks)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Information Integrity: Lowered barrier to entry to generate and support the exchange and consumption of content which may not distinguish fact from opinion or fiction or acknowledge uncertainties, or could be leveraged for large-scale dis- and mis-information campaigns (Information Integrity)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Information Security: Lowered barriers for offensive cyber capabilities, including via automated discovery and exploitation of vulnerabilities to ease hacking, malware, phishing, offensive cyber operations, or other cyberattacks; increased attack surface for targeted cyberattacks, which may compromise a system's availability or the confidentiality or integrity of training data, code, or model weights (Information Security / Offensive Cyber)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile

Intellectual Property: Eased production or replication of alleged copyrighted, trademarked, or licensed content without authorization (possibly in situations which do not fall under fair use); eased exposure of trade secrets; or plagiarism or illegal replication (Intellectual property leakage or mimicry)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Obscene, Degrading, and/or Abusive Content: Eased production of and access to obscene, degrading, and/or abusive imagery which can cause harm, including synthetic child sexual abuse material (CSAM), and nonconsensual intimate images (NCII) of adults (Abusive or obscene content)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Value Chain and Component Integration: Non-transparent or untraceable integration of upstream third-party components, including data that has been improperly obtained or not processed and cleaned due to increased automation from GAI; improper supplier vetting across the AI lifecycle; or other issues that diminish transparency or accountability for downstream users (Third-party data or component trustworthiness)	NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
Identify and mitigate harms to people, organizations, and ecosystems (Harms to people, organizations, and ecosystems)	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Prompt Injection	OWASP Top 10 for Large Language Model Applications
Sensitive Information Disclosure	OWASP Top 10 for Large Language Model Applications
Supply Chain	OWASP Top 10 for Large Language Model Applications
Data and Model Poisoning	OWASP Top 10 for Large Language Model Applications
Improper Output Handling	OWASP Top 10 for Large Language Model Applications
Excessive Agency	OWASP Top 10 for Large Language Model Applications
System Prompt Leakage	OWASP Top 10 for Large Language Model Applications

Vector and Embedding Weaknesses	OWASP Top 10 for Large Language Model Applications
Misinformation	OWASP Top 10 for Large Language Model Applications
Unbounded Consumption (Sponge Examples)	OWASP Top 10 for Large Language Model Applications
Data Poisoning	Google Secure AI Framework (SAIF)
Unauthorized Training Data	Google Secure AI Framework (SAIF)
Model Source Tampering	Google Secure AI Framework (SAIF)
Excessive Data Handling	Google Secure AI Framework (SAIF)
Model Exfiltration	Google Secure AI Framework (SAIF)
Model Deployment Tampering	Google Secure AI Framework (SAIF)
Denial of ML Service	Google Secure AI Framework (SAIF)
Model Reverse Engineering	Google Secure AI Framework (SAIF)
Insecure Integrated Component	Google Secure AI Framework (SAIF)
Prompt Injection	Google Secure AI Framework (SAIF)
Model Evasion	Google Secure AI Framework (SAIF)
Sensitive Data Disclosure	Google Secure AI Framework (SAIF)
Inferred Sensitive Data	Google Secure AI Framework (SAIF)
Insecure Model Output	Google Secure AI Framework (SAIF)
Rogue Actions	Google Secure AI Framework (SAIF)
Input Manipulation Attack	OWASP Machine Learning Security Top Ten
Data Poisoning Attack	OWASP Machine Learning Security Top Ten
Model Inversion Attack	OWASP Machine Learning Security Top Ten
Membership Inference Attack	OWASP Machine Learning Security Top Ten
Model Theft	OWASP Machine Learning Security Top Ten
AI Supply Chain Attacks	OWASP Machine Learning Security Top Ten

Transfer Learning Attack	OWASP Machine Learning Security Top Ten
Model Skewing	OWASP Machine Learning Security Top Ten
Output Integrity Attack	OWASP Machine Learning Security Top Ten
Model Poisoning	OWASP Machine Learning Security Top Ten
Transparency and Explainability Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Controllability and Autonomy Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Reliability and Robustness Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Security and Privacy Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Bias and Fairness Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Accountability and Traceability Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Safety and Resilience Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Data Quality and Integrity Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Human-AI Interaction Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Regulatory and Compliance Risks	ISO/IEC TR 24028: Information technology - Artificial intelligence - Overview of trustworthiness in artificial intelligence
Automated Decision-Making without Safeguards	General Data Protection Regulation (GDPR)

Transparency and Explainability Failures	General Data Protection Regulation (GDPR)
Unlawful Data Processing (No Legal Basis)	General Data Protection Regulation (GDPR)
Profiling Without Safeguards or Opt-Out	General Data Protection Regulation (GDPR)
Data Minimization / Overcollection	General Data Protection Regulation (GDPR)
Re-identification of Anonymized Data	General Data Protection Regulation (GDPR)
Inadequate Data Subject Rights Implementation	General Data Protection Regulation (GDPR)
Processing Special Category Data Without Safeguards	General Data Protection Regulation (GDPR)
Insecure AI Data or Models	General Data Protection Regulation (GDPR)
Insider Threat / Internal Misuse of AI	Insider Business Machine (IBM)
Inadequate Logging and Traceability	EU AI Act
Use of Prohibited AI Applications	EU AI Act
Algorithmic Bias and Discrimination	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Lack of Transparency and Explainability	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Data Privacy and Security Risks	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Unintended Consequences and Unforeseen Risks	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Autonomy and Human Oversight	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Model Robustness and Safety	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Accountability and Legal Liability	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
System Complexity and Maintenance	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Social, Ethical, and Economic Impacts	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management
Environmental Impact	ISO/IEC 23894:2023: Information technology - Artificial intelligence - Guidance on risk management

Lack of Incident Reporting Mechanisms	EU AI Act
GPAI (General Purpose AI) Compliance Gaps	EU AI Act
Non-disclosure of AI Usage to Users	EU AI Act
Failure to Ensure Human Oversight	EU AI Act
Dataset Quality and Bias Non-Compliance	EU AI Act
Lack of Risk Management System	EU AI Act
Absence of Conformity Assessment for High-Risk AI	EU AI Act
Misclassification of AI Risk Tier	EU AI Act
Jailbreak Attacks	Microsoft Threat Intelligence
Lack of training data transparency	IBM: AI risk atlas
Uncertain data provenance	IBM: AI risk atlas
Data bias	IBM: AI risk atlas
Improper retraining	IBM: AI risk atlas
Improper data curation	IBM: AI risk atlas
Data usage restrictions	IBM: AI risk atlas
Data acquisition restrictions	IBM: AI risk atlas
Data transfer restrictions	IBM: AI risk atlas
Data usage rights restrictions	IBM: AI risk atlas
Confidential information in data	IBM: AI risk atlas
Data poisoning	IBM: AI risk atlas
Personal information in data	IBM: AI risk atlas
Data privacy rights alignment	IBM: AI risk atlas
Reidentification	IBM: AI risk atlas
Data contamination	IBM: AI risk atlas
Unrepresentative data	IBM: AI risk atlas
Prompt injection attack	IBM: AI risk atlas

Extraction attack	IBM: AI risk atlas
Prompt leaking	IBM: AI risk atlas
Evasion attack	IBM: AI risk atlas
Confidential data in prompt	IBM: AI risk atlas
IP information in prompt	IBM: AI risk atlas
Jailbreaking	IBM: AI risk atlas
Prompt priming	IBM: AI risk atlas
Poor model accuracy	IBM: AI risk atlas
Membership inference attack	IBM: AI risk atlas
Attribute inference attack	IBM: AI risk atlas
Personal information in prompt	IBM: AI risk atlas
Non-disclosure	IBM: AI risk atlas
Improper usage	IBM: AI risk atlas
Spreading toxicity	IBM: AI risk atlas
Dangerous use	IBM: AI risk atlas
Nonconsensual use	IBM: AI risk atlas
Spreading disinformation	IBM: AI risk atlas
Inaccessible training data	IBM: AI risk atlas
Untraceable attribution	IBM: AI risk atlas
Unexplainable output	IBM: AI risk atlas
Unreliable source attribution	IBM: AI risk atlas
Exposing personal information	IBM: AI risk atlas
Incomplete advice	IBM: AI risk atlas
Harmful code generation	IBM: AI risk atlas
Over- or under-reliance	IBM: AI risk atlas
Toxic output	IBM: AI risk atlas

Harmful output	IBM: AI risk atlas
Hallucination	IBM: AI risk atlas
Copyright infringement	IBM: AI risk atlas
Revealing confidential information	IBM: AI risk atlas
Output bias	IBM: AI risk atlas
Decision bias	IBM: AI risk atlas
Model usage rights restrictions	IBM: AI risk atlas
Legal accountability	IBM: AI risk atlas
Generated content ownership and IP	IBM: AI risk atlas
Lack of system transparency	IBM: AI risk atlas
Unrepresentative risk testing	IBM: AI risk atlas
Incomplete usage definition	IBM: AI risk atlas
Lack of data transparency	IBM: AI risk atlas
Incorrect risk testing	IBM: AI risk atlas
Lack of model transparency	IBM: AI risk atlas
Lack of testing diversity	IBM: AI risk atlas
Impact on cultural diversity	IBM: AI risk atlas
Impact on education: plagiarism	IBM: AI risk atlas
Impact on jobs	IBM: AI risk atlas
Impact on education: bypassing learning	IBM: AI risk atlas
Impact on affected communities	IBM: AI risk atlas
Impact on the environment	IBM: AI risk atlas
Impact on human agency	IBM: AI risk atlas
Human exploitation	IBM: AI risk atlas
Compromised Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO

Agent Impersonation	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Agent Identity Attack	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Agent Tool Misuse	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Agent Goal Manipulation	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Marketplace Manipulation	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Integration Risks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Horizontal/Vertical Solution Vulnerabilities	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Repudiation	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Compromised Agent Registry	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Malicious Agent Discovery	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Agent Pricing Model Manipulation	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Inaccurate Agent Capability Description	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Security Agent Data Poisoning	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Evasion of Security AI Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Compromised Security AI Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Regulatory Non-Compliance by AI Security Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Bias in Security AI Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO

Lack of Explainability in Security AI Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Model Extraction of AI Security Agents	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Manipulation of Evaluation Metrics	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Compromised Observability Tools	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Denial of Service on Evaluation Infrastructure	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Evasion of Detection	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Data Leakage through Observability	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Poisoning Observability Data	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Compromised Container Images	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Orchestration Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Infrastructure-as-Code (IaC) Manipulation	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Denial of Service (DoS) Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Resource Hijacking	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Lateral Movement	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Compromised Framework Components	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Backdoor Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Input Validation Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO

Supply Chain Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Denial of Service on Framework APIs	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Framework Evasion	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Data Poisoning	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Data Exfiltration	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Model Inversion/Extraction	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Denial of Service on Data Infrastructure	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Data Tampering	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Compromised RAG Pipelines	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Adversarial Examples	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Model Stealing	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Membership Inference Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Reprogramming Attacks	CSA (Cloud Security Alliance): Agentic AI Threat Modeling Framework: MAESTRO
Emergent Goals/Behavior	Center for AI Safety (CAIS)
Unknown AI Risks	OECD: Advancing Accountability in AI
Physical Harm	EU AI Act, ISO/IEC 23894, NIST AI RMF
Psychological Harm	NIST AI RMF
Financial/Economic Harm	OECD AI Principles, EU AI Act, U.S. Treasury AI Report

Informational Harm	GDPR, ISO/IEC 23894, NIST Privacy Framework
Reputational Harm	NIST AI RMF
Discrimination & Inequity	EU AI Act, IBM
Autonomy and Agency Harm	OECD AI Principles, EU AI Act
Social & Democratic Harm	OECD Information Integrity
Environmental Harm	EU AI Office Environmental Guidance
Legal/Regulatory Harm	GDPR, EU AI Act
Operational Harm	MITRE ATLAS
Ethical/Value-Based Harm	OECD AI Principles
Semantic drift	AI at Meta
Multi-agent collusion	Google DeepMind Autonomy Risk Research

Appendix II:

Out of Scope Risks: Possible Alignment

Governance, Policy, and Ethical Controls	Human-AI Interaction & Societal Controls
Emergent Goals/Behavior	Human-AI Interaction Risks
Unknown AI Risks	Autonomy and Agency Harm
Ethical/Value-Based Harm	Psychological Harm
Regulatory Harm	Physical Harm
Use of Prohibited AI Applications	Social & Democratic Harm
Undisclosed AI Usage	Informational Harm
Maintenance Requirements	Reputational Harm
Semantic Drift	Discrimination & Inequity
Multi-agent Collusion	Financial Harm
Lower Offensive Cyber Barriers	Economic Harm
	Environmental Harm
	Legal Harm
	Operational Harm
	Improper usage
	Over-reliance
	Disinformation / Misinformation / Toxic / Harmful Content
AI Model Lifecycle and Operations Controls	Data Governance, Privacy, and Compliance Controls
Statistical uncertainty in pre-trained models	Biased Data
Side-effects not visible in statistical measures	Privacy risk due to enhanced data-aggregation capability for AI systems
Complex Systems	Data usage restrictions
Third-party data or component trustworthiness	
Unbounded Consumption (Sponge Examples)	
Controllability and Autonomy Risks	
Reliability and Robustness Risks	
Bias and Fairness Risks	
Safety and Resilience Risks	
Data Quality and Integrity Risks	
Automated Decision-Making without Safeguards	

Inadequate Data Subject Rights Implementation
Misclassification of AI risk tier
Poor model accuracy
Training-time perturbations
Model drift
Stale or context-detached datasets
Improper output handling
Data transparency
Data provenance
Improper Data Curation
Data retraining issues
Testing coverage gaps
Transparency Gaps
Explainability Gaps
Accountability Gaps
Logging Gaps

Data acquisition restrictions
Data transfer restrictions
Confidential information in data
Personal information in data
Regulatory & Compliance Risks
Data privacy rights
Intellectual property leakage
Intellectual property mimicry
Copyright infringement
Generated content intellectual property
Non-consensual use
Excessive Data Handling

About the Author

Brandon Lee is a cybersecurity leader specializing in offensive security with an emerging expertise in AI security and risk management.

Following his enlistment in the United States Navy as a nuclear electrician's mate, Brandon first pursued his degree in nuclear and radiological engineering at the Georgia Institute of Technology. However, lacking interest in his studies and struggling to financially support being a full-time student, Brandon instead obtained a bachelor's degree in mathematics en route to earning a Master of Science in Cybersecurity from the prestigious Thomas Edison State University. In addition, he holds nearly a dozen cybersecurity certifications, including the coveted CISSP certification, alongside the CEH, GPEN, AI-900, and AZ-900, to name a few.

Currently serving as a senior cyber defense manager for a global financial institution, Brandon leads a team of elite ethical hackers and oversees multiple offensive security functions, including cloud assessments, source code analysis, and whitebox web application penetration tests. He has been tasked with owning and leading the AI assurance function in anticipation of enterprise movement towards AI adoption.

Brandon is currently the sole author of the AI² Framework and is open to any suggestions. If you have any questions, comments, criticism, or feedback, please reach out to Brandon directly via LinkedIn: <https://www.linkedin.com/in/brandon-m-lee/>

Version Control

Version	Description		Date
1.0	Initial release for public consumption, review and feedback		04/17/2025
1.1	Grammatical fixes, formatting improvements		04/20/2025
1.2			04/29/2025
	v1.1 Section	Changes	
	Miscellaneous	1. Changed “risk-centric” to “risk-informed” 2. Cleaned up RMF section verbiage 3. Changed font to 1.5	
	Contents	1. Restructured numbering arrangement 2. Added page numbers to tables and figures 3. Updated section names to align with below changes	
	AI Types	1. Section title changed to AI Solutions 2. Introduced AI Solution Layers sub-framework 3. Added Multimodal distinctions 4. Added Agentic AI distinctions	
	Identify High-Risk AI	1. Cleaned up formatting issues 2. Realigned verbiage to fit better with AI Solutions change (see AI Types section above)	
	Adversary Imitation Assessment Methodology	1. Removed the overlap explanations chart.	
	About the Author	1. Added a more social “about the author” section that no one will read	



AI²

FRAMEWORK

ARTIFICIAL
INTELLIGENCE
ADVERSARY
IMITATION

Version 1.2